



AI Security Controls Architecture

Framework Definition Document; NS AISCA v1.0 · 2026 Edition

A comprehensive approach for establishing measurable, auditable, and continuously improving AI security aligned simultaneously to the EU AI Act, ISO/IEC 42001, ISO/IEC 27090, NIST AI RMF, OWASP LLM Top 10, MITRE ATLAS, CSA AICM, CISA/NCSC guidance, and Google SAIF

Measurable, Verifiable AI Security Technical Architecture for Every Model, Agent, and Attack Surface

108

Security Controls

Across 12 weighted domains

12

Security Domains

Mapped to AI attack surface layers

20+

Global Standards

EU AI Act · ISO 42001 · NIST ·
OWASP · MITRE

5

Maturity Levels

L1 Initial → L5 Optimizing

A unified, evidence-based AI security controls architecture for regulated high-impact organisational assurance.

The Nucleus Systems AI Security Controls Architecture (NS AISCA v1.0) is a proprietary, structured, and automation-ready approach to AI security for organisations that develop, deploy, procure, integrate, or operate AI in regulated and high-impact environments. With 108 fully defined AI security controls across 12 weighted domains, a five-level maturity model, five-grade evidence standard, and simultaneous alignment to leading AI security, AI governance, cybersecurity, and adversarial AI frameworks, it turns fragmented AI security obligations into a single evidence-based, board-ready architecture for continuous AI security assurance.

© 2026 Nucleus Systems (Pty) Ltd. All rights reserved. The Nucleus Systems AI Security Controls Architecture (NS AISCA v1.0) is a proprietary framework and intellectual property of Nucleus Systems. Unauthorised reproduction, distribution, or adaptation of this framework or its controls without written permission from Nucleus Systems is prohibited.

1. The AI Security Imperative

Artificial intelligence is no longer a contained experimental capability; it is embedded in enterprise workflows, customer interactions, software products, financial decisions, security operations, and autonomous agents. This shift creates a security problem that is structurally different from traditional application security because AI systems combine data, models, prompts, retrieval stores, tools, agents, APIs, cloud runtimes, and continuously changing external dependencies.

The new AI attack surface includes prompt injection, indirect prompt manipulation, training data poisoning, model theft, model inversion, membership inference, unsafe tool calls, excessive agent autonomy, RAG leakage, vector store authorisation failures, foundation model dependency risk, and adversarial examples. A conventional set of cybersecurity controls remains necessary, but it is no longer sufficient.

2026 is therefore the inflection point for AI security architecture. Organisations can no longer rely on acceptable-use policies, informal model reviews, isolated prompt filters or vendor assurances. They require a control-level, evidence-based and continuously monitored architecture that can be assessed, scored, reported and improved as AI systems evolve.

The Structural Shift from Cybersecurity to AI Security Architecture

NS AISCA is built on the principle that AI security must protect the entire AI decision-and-action chain. This means protecting not only infrastructure and code but also datasets, model artifacts, prompts, RAG stores, system instructions, agent memory, tools, permissions, telemetry, and evidence that demonstrates controls are operating.

The regulatory and standards convergence

This table summarises the external control environment that NS AISCA unifies. It explains which sources define legal obligations, management system requirements, AI risk methods, GenAI risks, AI adversary tactics, cloud AI controls, and secure AI development expectations. Each row identifies the framework role, the security obligations it contributes, and the remaining gap when used in isolation. It demonstrates why a dedicated AI security controls architecture is required rather than another fragmented compliance mapping exercise.

Framework	Role	Security Obligation	Coverage Gap Without NS AISCA
EU AI Act / Regulation (EU) 2024/1689	Binding AI regulation	Risk management, technical documentation, logging, cybersecurity, transparency, human oversight, monitoring and incident reporting.	Legal obligation without a complete technical AI security control catalogue.
ISO/IEC 42001:2023	AI Management System	Management-system structure, leadership, planning, support, operation, audit, corrective action and continual improvement.	Management structure without detailed technical AI security controls.
ISO/IEC 27090	AI cybersecurity guidance	Guidance for AI-specific security threats and compromises across lifecycle stages.	Threat guidance without maturity scoring and operating model.
NIST AI RMF + NIST AI 600-1	AI risk and GenAI profile	GOVERN, MAP, MEASURE and MANAGE functions, with a GenAI companion profile.	Risk grammar without a single implementation workbook across domains.
OWASP LLM Top 10	LLM and GenAI risk	Prompt injection, insecure output, data poisoning, model DoS, supply chain, sensitive disclosure and excessive agency.	Application risk taxonomy without enterprise scoring and board reporting.
MITRE ATLAS	AI adversary knowledge base	Adversarial tactics and techniques for AI threat modelling, detection engineering and red teaming.	Threat intelligence without governance, evidence and maturity architecture.
CISA / NSA / NCSC Secure AI Guidelines	Secure AI lifecycle	Secure design, development, deployment, operation and maintenance expectations.	Lifecycle guidance that must be converted into assessable controls.

Framework	Role	Security Obligation	Coverage Gap Without NS AISCA
CSA AICM and Google SAIF	Cloud AI and secure AI architecture	Cloud AI controls and secure AI framework for detection, response, automation and contextual risk.	Implementation guidance that needs integration into one operating model.

It shows that the AI security landscape is strong but fragmented. NS AISCA uses these sources as inputs and harmonises them into one security architecture. The result is a single evidence set, maturity score and roadmap that can serve regulators, auditors, engineers, boards and customers.

The AI security accountability model

This table outlines the security duties for the main roles in the AI ecosystem. It clarifies what each role is expected to secure, evidence and monitor when AI systems are built, bought, integrated or operated. This is achieved by separating obligations across providers, deployers, integrators, agent/tool owners and third-party suppliers. It is used during scoping to identify who must supply evidence for each control and who must approve residual risk.

Role	Who Is Affected	Primary Security Obligations
AI Providers / Developers	Organisations that develop, train, fine-tune, package or substantially modify AI systems.	Secure development, model registry, artifact integrity, data controls, adversarial testing, technical documentation and post-market monitoring.
AI Deployers / Users	Organisations that deploy AI systems under their authority, including vendor AI and GenAI tools.	Secure configuration, user access, human oversight, prompt and data safeguards, monitoring, incident response and vendor assurance.
AI Integrators / Product Teams	Teams embedding AI into applications, APIs, workflows, products or customer-facing services.	Threat modelling, secure architecture, validation, tool-call control, RAG authorisation, release gates and telemetry.
Agent and Tool Owners	Owners of autonomous workflows, tools, APIs, credentials, memory and downstream actions.	Permission scoping, autonomy limits, approval gates, sandboxing, kill-switches, tool registry and action monitoring.
Third-Party AI Suppliers	Foundation-model providers, cloud AI services, AI SaaS vendors, data suppliers and API providers.	Contractual controls, incident notification, retention limits, tenant isolation, update notification, audit rights, and supply chain evidence.

AI security failures often occur at handoff points between roles. Accountability becomes operational, measurable, and contractually visible. The result is stronger governance over third-party AI, agentic workflows, and product integrations.

The sector-context security exposure

This table defines how AI security priorities differ across industries. It shows which AI security risks matter most in each sector and which regulatory or operational exposures intensify security requirements. This is achieved by linking typical AI use cases to the most important security controls and external obligations applicable to that sector. It helps boards and CISOs calibrate NS AISCA target maturity according to business impact.

Sector	AI Security Priority	Key Security and Regulatory Exposure
Financial Services	Credit AI, fraud models, underwriting, trading assistants, robo-advice and customer GenAI.	Model integrity, explainability, data leakage prevention, transaction limits, vendor AI risk and resilience.
Government & Public Sector	Citizen-facing decision support, identity verification, benefits eligibility and public-safety analytics.	Human oversight, transparency, auditability, data minimisation, protected-group impact and public accountability.
Healthcare & Pharmaceuticals	Diagnostic support, clinical triage, patient communications, drug discovery and operational optimisation.	Health data protection, model validation, safety monitoring, human override, explainability, and incident containment.
Technology & AI Product Vendors	AI SaaS, model APIs, copilots, RAG products, autonomous agents and AI	Prompt security, model theft prevention, secure APIs, SBOM/AI-BOM, MLSecOps gates and customer

Sector	AI Security Priority	Key Security and Regulatory Exposure
	platforms.	assurance.
Energy & Critical Infrastructure	Predictive maintenance, grid optimisation and operational AI assistants.	Runtime hardening, autonomy limits, segmented workloads, continuity, resilience, red teaming and escalation.
Retail, Logistics & Manufacturing	Demand forecasting, pricing AI, warehouse automation, quality inspection and supply-chain optimisation.	API abuse controls, data protection, drift monitoring, pricing governance, third-party AI risk and continuity.

AI security is context-sensitive and risk-weighted. It helps organisations decide which systems require L3, L4 or L5 maturity. The result is more targeted investment, stronger regulatory posture and lower operational exposure.

2. The Answer to the AI Security Challenge

NS AISCA v1.0 was designed to bridge the gap between fragmented AI security guidance and the operational controls organisations need to secure real AI systems. It does not replace existing standards; it unifies them into a single assessment, scoring, evidence and improvement model.

NS AISCA provides 108 AI security controls organised into 12 weighted domains, assessed against a five-level maturity scale and constrained by a five-grade evidence standard. The framework covers governance, inventory, secure design, data security, model security, LLM and RAG security, agentic AI, MLSecOps, runtime security, monitoring, assurance and incident response.

The framework is designed as the technical-security counterpart to the Nucleus Systems AI Governance Framework and Maturity Measurement Model. NS-AIGF defines AI governance accountability; NS AISCA defines the security controls required to secure the AI decision-and-action chain.

The NS AISCA framework definition

This table provides the authoritative identity and structure of NS AISCA v1.0. It states what the framework is, what it covers, how it is measured, which standards it aligns with, and what tool ecosystem operationalises it. This table serves as a compact reference for clients, assessors, auditors, and executives. It anchors the rest of the document by establishing the number of controls, domains, maturity levels, evidence grades, and outputs.

Attribute	Detail
Framework Name	Nucleus Systems AI Security Controls Architecture
Framework Code	NS AISCA v1.0
Edition	Professional Edition — April 2026
Security Controls	108 controls fully defined with requirements, guidance, evidence expectations, and framework alignment
Security Domains	12 weighted domains mapped to the end-to-end AI attack surface
Domain Weights	D1 8% D2 8% D3 9% D4 9% D5 9% D6 10% D7 10% D8 9% D9 8% D10 8% D11 7% D12 5%
Maturity Scale	L1 Initial → L2 Managed → L3 Defined → L4 Quantitative → L5 Optimizing
Evidence Standard	E1 Informal → E2 Manual → E3 Structured → E4 System-generated → E5 Adaptive
Framework Alignment	EU AI Act ISO/IEC 42001 ISO/IEC 23894 ISO/IEC 27001 ISO/IEC 27090 NIST AI RMF NIST CSF NIST SSDF OWASP MITRE ATLAS CSA AICM CISA/NCSC Google SAIF
Assessment Tool	Workbook with 12 domain sheets, dropdown scoring, evidence register, automated gaps, standards mapping, dashboard, board report and roadmap
Delivery Model	Baseline → Gap Analysis → Remediation → Assurance → Continuous Assessment
Primary Purpose	Secure the AI attack surface through measurable, auditable and continuously improving technical controls

It defines NS AISCA as a complete architecture rather than a checklist. Every stakeholder can see the scope, measurement method and standards coverage at a glance. The result is a shared language for AI security maturity across engineering, security, risk, audit, procurement and board governance.

The NS AISCA design principles

This table defines the engineering philosophy behind every NS AISCA domain and control. It explains how the framework differs from generic cybersecurity frameworks, AI principles documents, and narrow LLM checklists. This is achieved by translating the philosophy into ten design rules for control design, scoring, evidence review, and assurance testing. It is used to preserve consistency as the control library evolves.

Design Principle	Description	Why It Matters
Security-by-Architecture	AI security is engineered into architecture, pipelines, runtime, monitoring, and incident response.	AI systems require protection at the decision and action layers, not only at network or application boundaries.
Control-Level Specificity	Every control addresses one auditable, evidence-driven requirement.	Specific controls produce reproducible maturity scores and audit-ready evidence.
Full AI Lifecycle Coverage	Controls span discovery, design, data, model, prompt, RAG, agent, tool, pipeline, runtime, monitoring and retirement.	AI security failures can occur at any stage of the AI lifecycle.
Threat-Informed Design	Controls reflect adversarial ML, LLM abuse, data poisoning, model extraction, agentic misuse and supply-chain compromise.	Threat-informed controls link architecture to real attacker behaviour.
Regulatory Traceability	Every control maps to recognised sources in AI law, AI management, AI risk, cybersecurity, and GenAI security.	Traceability turns security evidence into regulatory evidence.
Evidence-Grade Maturity	Maturity is constrained by evidence quality, not documentation volume.	High maturity must be proven through structured, system-generated, or adaptive evidence.
Zero-Trust AI Execution	No model, prompt, tool, dataset, vector store, agent, API, memory, or output is inherently trusted.	AI interactions involve untrusted instructions and dynamic context.
Least Autonomy by Default	Agents and tools receive the minimum permissions, context, memory, tool access, and action scope required.	Excessive agency is a material emerging GenAI risk.
Continuous Validation	AI security is retested when models, prompts, data, tools, vendors, architectures, or threats change.	Point-in-time testing is insufficient for continuously evolving systems.
Board-Ready Measurement	The framework produces scores, KRIs, heatmaps, gaps, evidence status, roadmaps, and assurance posture.	AI security must be governed as a board-level risk.

It explains why NS AISCA is architected from first principles for AI security. Assessors and client teams can apply the same reasoning across all 108 controls. The result is a framework that remains extensible as AI systems, regulations and attacker techniques evolve.

3. Framework Architecture — 12 Domains, 108 Controls

NS AISCA organises 108 controls into twelve domains. The domains are sequenced to reflect implementation dependencies: governance establishes authority; inventory creates visibility; threat modelling shapes architecture; data and model controls protect the foundations; LLM and agent controls secure interactions and autonomy; MLSecOps and runtime controls enforce security; monitoring and assurance validate effectiveness; and incident response sustains resilience.

The weighted domain architecture

This table defines the top-level architecture of NS AISCA v1.0. It shows how the controls are grouped, how each domain contributes to the overall maturity score, and what security intent each domain serves. This is achieved by assigning a percentage weight to each domain based on AI security exposure and operational significance. It is used by the assessment workbook to calculate the weighted overall AISCA score.

Domain	Domain Name	Weight	Controls	Security Intent
D1	AI Security Governance & Accountability	8%	9 controls	Executive ownership, security policy, risk appetite, exceptions, control ownership, training and board reporting.
D2	AI Asset Inventory, Exposure & Classification	8%	9 controls	Complete visibility of AI assets, shadow AI, exposure classification, AI-BOM, ownership and high-risk reconciliation.
D3	AI Threat Modelling & Secure Design	9%	9 controls	Threat modelling, misuse cases, trust boundaries, secure patterns, human oversight and design review gates.
D4	Data, Privacy & Training-Set Security	9%	9 controls	Dataset lineage, poisoning prevention, privacy controls, vector authorisation, retention and data exfiltration prevention.
D5	Model, Artifact & IP Security	9%	9 controls	Model registry, artifact signing, model access least privilege, model extraction prevention, rollback and IP controls.
D6	LLM, Prompt, RAG & GenAI Application Security	10%	9 controls	Prompt injection defence, system prompt protection, input/output validation, RAG authorisation, tool validation and telemetry.
D7	Agentic AI, Tool & Autonomy Security	10%	9 controls	Agent permission scopes, tool registry, approval gates, autonomy limits, memory governance, sandboxing and kill switches.
D8	MLOps, MLSecOps & AI Supply Chain Security	9%	9 controls	Repository security, pipeline gates, supply-chain risk, SBOM/AI-BOM linkage, dependency scanning and reproducibility.
D9	Runtime, Cloud, API & Platform Security	8%	9 controls	Workload segmentation, endpoint protection, API security, runtime hardening, secret management, encryption and tenant isolation.
D10	AI Security Monitoring, Logging & Detection	8%	9 controls	Security event logging, tamper-evident logs, AI threat detection, drift monitoring, SOC integration and forensic readiness.
D11	AI Assurance, Red Teaming & Independent Validation	7%	9 controls	Security test plans, adversarial testing, LLM and agent red teaming, regression testing and independent validation.
D12	AI Incident Response, Resilience & Continuous Compliance	5%	9 controls	AI incident playbooks, severity criteria, reporting triggers, emergency containment, continuity and reassessment.

It prevents equal-weight scoring from hiding critical weaknesses in high-exposure areas. Overall maturity reflects actual AI security exposure rather than a simple average of activities. The result is a more defensible prioritisation model for investment, remediation and board reporting.

The domain control summary

This table defines the representative control themes within each NS AISCA domain. It provides a quick operational map of the control focus areas contained in each domain. This is achieved by naming each domain and listing representative controls to show how each domain translates into practical implementation work. It is used during executive briefings, scoping workshops, and assessment preparation.

Domain	Name	Controls	Representative Controls
D1	AI Security Governance & Accountability	9	AI Security Executive Accountability AI Security Policy Framework AI Security Risk Appetite AI Use-Case Security Approval AI Security Roles and Responsibilities
D2	AI Asset Inventory, Exposure & Classification	9	AI Asset Inventory Shadow AI Discovery AI Exposure Classification AI Bill of Materials Data-Flow and Decision-Flow Mapping
D3	AI Threat Modelling & Secure	9	AI Threat Modelling Misuse and Abuse Case Analysis Trust

Domain	Name	Controls	Representative Controls
	Design		Boundary Definition Secure Reference Architectures Security Requirements in AI Design
D4	Data, Privacy & Training-Set Security	9	Dataset Lineage and Provenance Data Poisoning Prevention Sensitive Data Identification and Minimisation Lawful Basis and Consent for AI Data Least-Privilege Data Access
D5	Model, Artifact & IP Security	9	Secure Model Registry Model Artifact Integrity and Signing Model Access Least Privilege Model Theft and Extraction Prevention Model Inversion and Membership-Inference Risk Assessment
D6	LLM, Prompt, RAG & GenAI Application Security	9	Prompt Injection Defence System Prompt and Orchestration Protection Input Validation for GenAI Output Validation and Response Safety RAG Retrieval Authorisation
D7	Agentic AI, Tool & Autonomy Security	9	Agent Permission Scoping Tool Registry and Tool Risk Classification Human Approval Gates for High-Impact Actions Agent Autonomy Limits Agent Memory Governance
D8	MLOps, MLSecOps & AI Supply Chain Security	9	AI Repository Security MLSecOps Pipeline Gates AI Supply-Chain Risk Assessment SBOM and AI-BOM Linkage Model and Dataset Dependency Scanning
D9	Runtime, Cloud, API & Platform Security	9	AI Workload Segmentation AI Endpoint Protection AI API Security Controls Secure Inference Runtime Baselines Secrets and Key Management for AI
D10	AI Security Monitoring, Logging & Detection	9	AI Security Event Logging Tamper-Evident Log Management AI-Specific Threat Detection Model Drift and Behaviour Monitoring SOC, SIEM and SOAR Integration
D11	AI Assurance, Red Teaming & Independent Validation	9	AI Security Test Plans Adversarial ML Testing LLM Red Teaming Agentic AI Red Teaming AI Security Regression Testing
D12	AI Incident Response, Resilience & Continuous Compliance	9	AI Incident Response Playbooks AI Incident Severity Criteria Regulatory and Contractual Reporting Triggers Emergency Rollback, Freeze and Shutdown Post-Incident Review and Control Improvement

It translates the 12-domain architecture into recognisable work packages. Executives can see the breadth of coverage before reading all controls. The result is faster stakeholder alignment and better assessment readiness.

4. Domain 1 — AI Security Governance & Accountability

Weight: 8% | Controls: AISCA-01 to AISCA-09 | Executive ownership, security policy, risk appetite, exceptions, control ownership, training and board reporting.

Domain 1 establishes the NS AISCA control layer for AI security governance & accountability. It defines the technical, operational and evidentiary controls that must be implemented for AI systems in scope. The domain is assessed independently, but its maturity also contributes to the overall weighted AISCA score. Controls in this domain should be interpreted in proportion to AI exposure, regulatory obligations, system criticality and target maturity.

Domain 1 control catalogue

This table outlines the nine AI security controls that comprise AI Security Governance & Accountability. It describes the core requirement and multi-framework alignment for each control so that assessors can score maturity consistently. This is achieved by converting a broad domain objective into specific auditable requirements that can be assigned to owners, evidenced, tested and remediated. It is used directly in the NS AISCA assessment workbook for current maturity, target maturity, gap calculation and roadmap priority.

#	Control Name	Core Requirement	Framework Alignment
AISCA-01	AI Security Executive Accountability	A named executive is accountable for AI security outcomes, funding, risk acceptance, target maturity and board reporting across enterprise AI systems,	EU AI Act Art. 9, 15 ISO/IEC 42001 §5-7 ISO/IEC 27090 governance NIST AI RMF

#	Control Name	Core Requirement	Framework Alignment
		GenAI applications, agents and AI-enabled products.	GOVERN NIST CSF GV CSA AICM governance CISA/NCSC governance Google SAIF control harmonisation
AISCA-02	AI Security Policy Framework	A documented AI security policy suite defines mandatory security requirements for models, prompts, RAG, agents, data pipelines, APIs, tools, infrastructure and AI vendors.	EU AI Act Art. 9, 15 ISO/IEC 42001 §5-7 ISO/IEC 27090 governance NIST AI RMF GOVERN NIST CSF GV CSA AICM governance CISA/NCSC governance Google SAIF control harmonisation
AISCA-03	AI Security Risk Appetite	AI security risk appetite defines unacceptable, high, medium and low exposure across confidentiality, integrity, availability, safety, autonomy, adversarial misuse and regulatory impact.	EU AI Act Art. 9, 15 ISO/IEC 42001 §5-7 ISO/IEC 27090 governance NIST AI RMF GOVERN NIST CSF GV CSA AICM governance CISA/NCSC governance Google SAIF control harmonisation
AISCA-04	AI Use-Case Security Approval	Every material AI use case requires security review before production release or external exposure, including risk classification, data sensitivity, autonomy level and monitoring readiness.	EU AI Act Art. 9, 15 ISO/IEC 42001 §5-7 ISO/IEC 27090 governance NIST AI RMF GOVERN NIST CSF GV CSA AICM governance CISA/NCSC governance Google SAIF control harmonisation
AISCA-05	AI Security Roles and Responsibilities	Roles and responsibilities are defined for providers, deployers, integrators, model owners, data owners, product owners, vendor owners, security teams and audit functions.	EU AI Act Art. 9, 15 ISO/IEC 42001 §5-7 ISO/IEC 27090 governance NIST AI RMF GOVERN NIST CSF GV CSA AICM governance CISA/NCSC governance Google SAIF control harmonisation
AISCA-06	AI Security Exception Management	AI security exceptions require documented justification, compensating controls, expiry dates, accountable owners and authorised risk acceptance.	EU AI Act Art. 9, 15 ISO/IEC 42001 §5-7 ISO/IEC 27090 governance NIST AI RMF GOVERN NIST CSF GV CSA AICM governance CISA/NCSC governance Google SAIF control harmonisation
AISCA-07	Board and Executive AI Security Reporting	Board and executive reporting includes AI security posture, high-risk AI systems, incidents, KRIs, control failures, remediation ageing, target maturity and assurance outcomes.	EU AI Act Art. 9, 15 ISO/IEC 42001 §5-7 ISO/IEC 27090 governance NIST AI RMF GOVERN NIST CSF GV CSA AICM governance CISA/NCSC governance Google SAIF control harmonisation
AISCA-08	AI Security Training and Competence	Role-based AI security training is required for developers, data scientists, product owners, SOC analysts, risk teams, procurement teams and business users.	EU AI Act Art. 9, 15 ISO/IEC 42001 §5-7 ISO/IEC 27090 governance NIST AI RMF GOVERN NIST CSF GV CSA AICM governance CISA/NCSC governance Google SAIF control harmonisation
AISCA-09	Control Ownership and Evidence Accountability	Every NS AISCA control has a named owner responsible for implementation, evidence maintenance, target maturity and remediation progress.	EU AI Act Art. 9, 15 ISO/IEC 42001 §5-7 ISO/IEC 27090 governance NIST AI RMF GOVERN NIST CSF GV CSA AICM governance CISA/NCSC governance Google SAIF control harmonisation

It makes AI security governance & accountability measurable at the control level rather than leaving them as broad principles. Each control has a requirement and cross-framework mapping that can be audited and improved. The result is a reproducible maturity score and a clear remediation path for the domain.

5. Domain 2 — AI Asset Inventory, Exposure & Classification

Weight: 8% | Controls: AISCA-10 to AISCA-18 | Complete visibility of AI assets, shadow AI, exposure classification, AI-BOM, ownership and high-risk reconciliation.

Domain 2 establishes the NS AISCA control layer for AI asset inventory, exposure & classification. It defines the technical, operational and evidentiary controls that must be implemented for AI systems in scope. The domain is assessed independently, but its maturity also contributes to the overall weighted AISCA score. Controls in this domain should be interpreted in proportion to AI exposure, regulatory obligations, system criticality and target maturity.

Domain 2 control catalogue

This table defines the nine AI security controls that make up AI Asset Inventory, Exposure & Classification. It describes the core requirement and multi-framework alignment for each control so that assessors can score maturity consistently. This is achieved by converting a broad domain objective into specific auditable requirements that can be assigned to owners, evidenced, tested, and remediated. It is used directly in the NS AISCA assessment workbook for current maturity, target maturity, gap calculation, and roadmap priority.

#	Control Name	Core Requirement	Framework Alignment
AISCA-10	AI Asset Inventory	A complete AI inventory covers models, datasets, prompts, agents, tools, APIs, vector stores, embeddings, plugins, vendors, cloud AI services, and AI-enabled products.	EU AI Act Art. 6, 9, 11, 50, Annex III ISO/IEC 42001 §4, §8 ISO/IEC 27090 exposure NIST AI RMF MAP NIST CSF ID CSA AICM asset governance CISA/NCSC secure design
AISCA-11	Shadow AI Discovery	Processes detect and assess unsanctioned AI tools, unmanaged GenAI usage, unapproved API calls and informal AI deployment patterns across the organisation.	EU AI Act Art. 6, 9, 11, 50, Annex III ISO/IEC 42001 §4, §8 ISO/IEC 27090 exposure NIST AI RMF MAP NIST CSF ID CSA AICM asset governance CISA/NCSC secure design
AISCA-12	AI Exposure Classification	AI systems are classified by business criticality, external exposure, data sensitivity, autonomy level, model type, regulatory relevance and third-party dependency.	EU AI Act Art. 6, 9, 11, 50, Annex III ISO/IEC 42001 §4, §8 ISO/IEC 27090 exposure NIST AI RMF MAP NIST CSF ID CSA AICM asset governance CISA/NCSC secure design
AISCA-13	AI Bill of Materials	An AI-BOM is maintained for AI-enabled products and material AI systems, covering models, datasets, prompts, code, libraries, APIs, plugins, tools, vendors and infrastructure.	EU AI Act Art. 6, 9, 11, 50, Annex III ISO/IEC 42001 §4, §8 ISO/IEC 27090 exposure NIST AI RMF MAP NIST CSF ID CSA AICM asset governance CISA/NCSC secure design
AISCA-14	Data-Flow and Decision-Flow Mapping	Data-flow and decision-flow maps show how inputs move through prompts, retrieval layers, models, tools, human checkpoints, and downstream systems.	EU AI Act Art. 6, 9, 11, 50, Annex III ISO/IEC 42001 §4, §8 ISO/IEC 27090 exposure NIST AI RMF MAP NIST CSF ID CSA AICM asset governance CISA/NCSC secure design
AISCA-15	Model Cards and Security Cards	Production AI systems maintain model cards and security cards that cover intended use, limitations, data sensitivity, risks, security controls, evaluations,	EU AI Act Art. 6, 9, 11, 50, Annex III ISO/IEC 42001 §4, §8 ISO/IEC 27090 exposure

#	Control Name	Core Requirement	Framework Alignment
		and monitoring requirements.	NIST AI RMF MAP NIST CSF ID CSA AICM asset governance CISA/NCSC secure design
AISCA-16	AI Ownership Records	Ownership records identify the business owner, technical owner, security owner, data owner, vendor owner, and risk owner for every AI system.	EU AI Act Art. 6, 9, 11, 50, Annex III ISO/IEC 42001 §4, §8 ISO/IEC 27090 exposure NIST AI RMF MAP NIST CSF ID CSA AICM asset governance CISA/NCSC secure design
AISCA-17	AI Lifecycle Status Tracking	Every AI asset has a lifecycle status such as experimental, approved, production, restricted, suspended, retired, or decommissioned.	EU AI Act Art. 6, 9, 11, 50, Annex III ISO/IEC 42001 §4, §8 ISO/IEC 27090 exposure NIST AI RMF MAP NIST CSF ID CSA AICM asset governance CISA/NCSC secure design
AISCA-18	High-Risk AI Inventory Reconciliation	The AI inventory is reconciled with the EU AI Act, sectoral regulations, data protection law, and internal criticality criteria to identify high-risk AI systems.	EU AI Act Art. 6, 9, 11, 50, Annex III ISO/IEC 42001 §4, §8 ISO/IEC 27090 exposure NIST AI RMF MAP NIST CSF ID CSA AICM asset governance CISA/NCSC secure design

It makes AI Asset Inventory, Exposure & Classification measurable at the control level rather than leaving them as broad principles. Each control has a requirement and cross-framework mapping that can be audited and improved. The result is a reproducible maturity score and a clear remediation path for the domain.

6. Domain 3 — AI Threat Modelling & Secure Design

Weight: 9% | Controls: AISCA-19 to AISCA-27 | Threat modelling, misuse cases, trust boundaries, secure patterns, human oversight and design review gates.

Domain 3 establishes the NS AISCA control layer for AI Threat Modelling & Secure Design. It defines the technical, operational and evidentiary controls that must be implemented for AI systems in scope. The domain is assessed independently, but its maturity also contributes to the overall weighted AISCA score. Controls in this domain should be interpreted in proportion to AI exposure, regulatory obligations, system criticality and target maturity.

Domain 3 control catalogue

This table outlines the nine AI security controls that comprise AI Threat Modelling & Secure Design. It describes the core requirement and multi-framework alignment for each control so that assessors can score maturity consistently. This is achieved by converting a broad domain objective into specific auditable requirements that can be assigned to owners, evidenced, tested and remediated. It is used directly in the NS AISCA assessment workbook for current maturity, target maturity, gap calculation and roadmap priority.

#	Control Name	Core Requirement	Framework Alignment
AISCA-19	AI Threat Modelling	Threat modelling is mandatory for high-impact, external-facing, autonomous, sensitive-data or high-risk AI systems.	EU AI Act Art. 9, 14, 15 ISO/IEC 42001 §6, §8 ISO/IEC 23894 ISO/IEC 27090 lifecycle threats NIST AI RMF MAP/MEASURE/MANAGE NIST SSDF MITRE ATLAS CISA/NCSC secure design Google SAIF
AISCA-20	Misuse and Abuse Case Analysis	AI misuse and abuse cases are documented before release, including malicious prompts, data	EU AI Act Art. 9, 14, 15 ISO/IEC 42001 §6, §8 ISO/IEC 23894

#	Control Name	Core Requirement	Framework Alignment
		exfiltration, model manipulation, tool misuse, excessive agency, and harmful outputs.	ISO/IEC 27090 lifecycle threats NIST AI RMF MAP/MEASURE/MANAGE NIST SSDF MITRE ATLAS CISA/NCSC secure design Google SAIF
AISCA-21	Trust Boundary Definition	Trust boundaries are explicitly defined across users, prompts, context windows, retrieval stores, models, APIs, agents, tools, data stores and downstream systems.	EU AI Act Art. 9, 14, 15 ISO/IEC 42001 §6, §8 ISO/IEC 23894 ISO/IEC 27090 lifecycle threats NIST AI RMF MAP/MEASURE/MANAGE NIST SSDF MITRE ATLAS CISA/NCSC secure design Google SAIF
AISCA-22	Secure Reference Architectures	Secure reference architectures are defined for chatbots, RAG systems, AI APIs, autonomous agents, MLSecOps pipelines, fine-tuning, and third-party foundation model use.	EU AI Act Art. 9, 14, 15 ISO/IEC 42001 §6, §8 ISO/IEC 23894 ISO/IEC 27090 lifecycle threats NIST AI RMF MAP/MEASURE/MANAGE NIST SSDF MITRE ATLAS CISA/NCSC secure design Google SAIF
AISCA-23	Security Requirements in AI Design	Security requirements are captured during AI design and are traceable to tests, evidence, and release gates.	EU AI Act Art. 9, 14, 15 ISO/IEC 42001 §6, §8 ISO/IEC 23894 ISO/IEC 27090 lifecycle threats NIST AI RMF MAP/MEASURE/MANAGE NIST SSDF MITRE ATLAS CISA/NCSC secure design Google SAIF
AISCA-24	Human Oversight Engineering	Human oversight and intervention points are engineered into AI workflows where decisions are high-impact or autonomous actions occur.	EU AI Act Art. 9, 14, 15 ISO/IEC 42001 §6, §8 ISO/IEC 23894 ISO/IEC 27090 lifecycle threats NIST AI RMF MAP/MEASURE/MANAGE NIST SSDF MITRE ATLAS CISA/NCSC secure design Google SAIF
AISCA-25	Layered AI Guardrail Design	Safety and security guardrails are designed as layered controls across input, prompt, retrieval, tool, model, output, monitoring, and human escalation layers.	EU AI Act Art. 9, 14, 15 ISO/IEC 42001 §6, §8 ISO/IEC 23894 ISO/IEC 27090 lifecycle threats NIST AI RMF MAP/MEASURE/MANAGE NIST SSDF MITRE ATLAS CISA/NCSC secure design Google SAIF
AISCA-26	Enhanced Design Assurance for Consequential AI	AI systems with physical, financial, legal, health, employment or public-service impact require enhanced design assurance.	EU AI Act Art. 9, 14, 15 ISO/IEC 42001 §6, §8 ISO/IEC 23894 ISO/IEC 27090 lifecycle threats NIST AI RMF MAP/MEASURE/MANAGE NIST SSDF MITRE ATLAS CISA/NCSC secure design Google SAIF
AISCA-27	AI Design Review Gates	Design review gates prevent AI systems from moving to build, test, or production without approved security architecture.	EU AI Act Art. 9, 14, 15 ISO/IEC 42001 §6, §8 ISO/IEC 23894 ISO/IEC 27090 lifecycle threats NIST AI RMF MAP/MEASURE/MANAGE NIST SSDF MITRE ATLAS CISA/NCSC secure design Google SAIF

It makes AI Threat Modelling & Secure Design measurable at control level rather than leaving it as a broad principle. Each control has a requirement and cross-framework mapping that can be audited and improved. The result is a reproducible maturity score and a clear remediation path for the domain.

7. Domain 4 — Data, Privacy & Training-Set Security

Weight: 9% | Controls: AISCA-28 to AISCA-36 | Dataset lineage, poisoning prevention, privacy controls, vector authorisation, retention and data exfiltration prevention.

Domain 4 establishes the NS AISCA control layer for data, privacy & training-set security. It defines the technical, operational and evidentiary controls that must be implemented for AI systems in scope. The domain is assessed independently, but its maturity also contributes to the overall weighted AISCA score. Controls in this domain should be interpreted in proportion to AI exposure, regulatory obligations, system criticality and target maturity.

Domain 4 control catalogue

This table defines the nine AI security controls that make up Data, Privacy & Training-Set Security. It describes the core requirement and multi-framework alignment for each control so that assessors can score maturity consistently. This is achieved by converting a broad domain objective into specific auditable requirements that can be assigned to owners, evidenced, tested and remediated. It is used directly in the NS AISCA assessment workbook for current maturity, target maturity, gap calculation and roadmap priority.

#	Control Name	Core Requirement	Framework Alignment
AISCA-28	Dataset Lineage and Provenance	Training, tuning, evaluation and retrieval datasets have documented lineage, source provenance, transformation history and approval status.	EU AI Act Art. 10, 12, 15 ISO/IEC 42001 §8 ISO/IEC 27001 data controls ISO/IEC 27090 data threats NIST AI RMF MAP/MEASURE OWASP LLM03/LLM06 MITRE ATLAS poisoning CSA AICM data security
AISCA-29	Data Poisoning Prevention	Controls validate source integrity, contributor identity, dataset change history, anomalous samples, and unusual distribution shifts before data enters AI pipelines.	EU AI Act Art. 10, 12, 15 ISO/IEC 42001 §8 ISO/IEC 27001 data controls ISO/IEC 27090 data threats NIST AI RMF MAP/MEASURE OWASP LLM03/LLM06 MITRE ATLAS poisoning CSA AICM data security
AISCA-30	Sensitive Data Identification and Minimisation	Sensitive data is identified, classified, minimised and protected before AI use across training data, prompts, logs, embeddings, vector stores and outputs.	EU AI Act Art. 10, 12, 15 ISO/IEC 42001 §8 ISO/IEC 27001 data controls ISO/IEC 27090 data threats NIST AI RMF MAP/MEASURE OWASP LLM03/LLM06 MITRE ATLAS poisoning CSA AICM data security
AISCA-31	Lawful Basis and Consent for AI Data	Personal data processing in AI systems has documented lawful basis, consent basis, or approved exemption, with withdrawal and deletion obligations linked to AI data flows.	EU AI Act Art. 10, 12, 15 ISO/IEC 42001 §8 ISO/IEC 27001 data controls ISO/IEC 27090 data threats NIST AI RMF MAP/MEASURE OWASP LLM03/LLM06 MITRE ATLAS poisoning CSA AICM data security
AISCA-32	Least-Privilege Data Access	Training and inference data access follows the principles of least privilege, separation of duties, and need-to-know.	EU AI Act Art. 10, 12, 15 ISO/IEC 42001 §8 ISO/IEC 27001 data controls ISO/IEC 27090 data threats NIST AI RMF MAP/MEASURE OWASP

#	Control Name	Core Requirement	Framework Alignment
			LLM03/LLM06 MITRE ATLAS poisoning CSA AICM data security
AISCA-33	Vector Database Authorisation	Vector databases and embedding stores preserve source access controls and enforce document-level, user-level and context-level authorisation.	EU AI Act Art. 10, 12, 15 ISO/IEC 42001 §8 ISO/IEC 27001 data controls ISO/IEC 27090 data threats NIST AI RMF MAP/MEASURE OWASP LLM03/LLM06 MITRE ATLAS poisoning CSA AICM data security
AISCA-34	Data Quality and Representativeness Assessment	Data quality, representativeness, completeness, bias indicators, and outlier patterns are assessed before model use.	EU AI Act Art. 10, 12, 15 ISO/IEC 42001 §8 ISO/IEC 27001 data controls ISO/IEC 27090 data threats NIST AI RMF MAP/MEASURE OWASP LLM03/LLM06 MITRE ATLAS poisoning CSA AICM data security
AISCA-35	AI Data Retention and Deletion	Retention and deletion controls apply to prompts, completions, logs, embeddings, fine-tuning datasets, model outputs, and retrieved content.	EU AI Act Art. 10, 12, 15 ISO/IEC 42001 §8 ISO/IEC 27001 data controls ISO/IEC 27090 data threats NIST AI RMF MAP/MEASURE OWASP LLM03/LLM06 MITRE ATLAS poisoning CSA AICM data security
AISCA-36	AI Data Exfiltration Prevention	Controls prevent sensitive data leakage through prompts, retrieval results, model outputs, logs, telemetry, agent memory, or tool calls.	EU AI Act Art. 10, 12, 15 ISO/IEC 42001 §8 ISO/IEC 27001 data controls ISO/IEC 27090 data threats NIST AI RMF MAP/MEASURE OWASP LLM03/LLM06 MITRE ATLAS poisoning CSA AICM data security

It makes Data, Privacy & Training-Set Security measurable at the control level rather than leaving them as broad principles. Each control has a requirement and cross-framework mapping that can be audited and improved. The result is a reproducible maturity score and a clear remediation path for the domain.

8. Domain 5 — Model, Artifact & IP Security

Weight: 9% | Controls: AISCA-37 to AISCA-45 | Model registry, artifact signing, model access least privilege, model extraction prevention, rollback and IP controls.

Domain 5 establishes the NS AISCA control layer for model, artifact & IP security. It defines the technical, operational and evidentiary controls that must be implemented for AI systems in scope. The domain is assessed independently, but its maturity also contributes to the overall weighted AISCA score. Controls in this domain should be interpreted in proportion to AI exposure, regulatory obligations, system criticality and target maturity.

Domain 5 control catalogue

This table defines the nine AI security controls that make up Model, Artifact & IP Security. It describes the core requirement and multi-framework alignment for each control so that assessors can score maturity consistently. This is achieved by converting a broad domain objective into specific auditable requirements that can be assigned to owners, evidenced, tested and remediated. It is used directly in the NS AISCA assessment workbook for current maturity, target maturity, gap calculation and roadmap priority.

#	Control Name	Core Requirement	Framework Alignment
AISCA-37	Secure Model Registry	A model registry tracks approved models, versions, owners, dependencies, deployment locations, risk class, security status, and retirement dates.	EU AI Act Art. 9, 11, 12, 15, 72 ISO/IEC 42001 §8/§9 ISO/IEC 27090 model compromise NIST AI RMF MEASURE/MANAGE OWASP LLM05 MITRE ATLAS model theft/inversion CSA AICM model security
AISCA-38	Model Artifact Integrity and Signing	Model artifacts are signed, versioned, access-controlled, and integrity-checked before promotion between environments.	EU AI Act Art. 9, 11, 12, 15, 72 ISO/IEC 42001 §8/§9 ISO/IEC 27090 model compromise NIST AI RMF MEASURE/MANAGE OWASP LLM05 MITRE ATLAS model theft/inversion CSA AICM model security
AISCA-39	Model Access Least Privilege	Access to models, weights, training environments, fine-tuning jobs, evaluation datasets, and inference endpoints follows a least-privilege model.	EU AI Act Art. 9, 11, 12, 15, 72 ISO/IEC 42001 §8/§9 ISO/IEC 27090 model compromise NIST AI RMF MEASURE/MANAGE OWASP LLM05 MITRE ATLAS model theft/inversion CSA AICM model security
AISCA-40	Model Theft and Extraction Prevention	Model theft prevention includes rate limits, query monitoring, output throttling, watermarking where appropriate, anomaly detection, and anti-probing controls.	EU AI Act Art. 9, 11, 12, 15, 72 ISO/IEC 42001 §8/§9 ISO/IEC 27090 model compromise NIST AI RMF MEASURE/MANAGE OWASP LLM05 MITRE ATLAS model theft/inversion CSA AICM model security
AISCA-41	Model Inversion and Membership-Inference Risk Assessment	Model inversion and membership-inference risks are assessed for models trained on sensitive or personal data.	EU AI Act Art. 9, 11, 12, 15, 72 ISO/IEC 42001 §8/§9 ISO/IEC 27090 model compromise NIST AI RMF MEASURE/MANAGE OWASP LLM05 MITRE ATLAS model theft/inversion CSA AICM model security
AISCA-42	Fine-Tuning Change Control	Fine-tuning requires approved datasets, security and privacy reviews, model change impact assessment, regression testing, and rollback planning.	EU AI Act Art. 9, 11, 12, 15, 72 ISO/IEC 42001 §8/§9 ISO/IEC 27090 model compromise NIST AI RMF MEASURE/MANAGE OWASP LLM05 MITRE ATLAS model theft/inversion CSA AICM model security
AISCA-43	Evaluation Dataset Protection	Evaluation datasets are protected from contamination, leakage, optimisation gaming and unauthorised access.	EU AI Act Art. 9, 11, 12, 15, 72 ISO/IEC 42001 §8/§9 ISO/IEC 27090 model compromise NIST AI RMF MEASURE/MANAGE OWASP LLM05 MITRE ATLAS model theft/inversion CSA AICM model security
AISCA-44	Model Rollback and Quarantine	Model rollback and quarantine procedures exist for compromised, unsafe, degraded, or non-compliant models.	EU AI Act Art. 9, 11, 12, 15, 72 ISO/IEC 42001 §8/§9 ISO/IEC 27090 model compromise NIST AI RMF MEASURE/MANAGE OWASP LLM05 MITRE ATLAS model theft/inversion CSA AICM model security
AISCA-45	Model IP, Licensing and Open-Source Risk	Model IP, licensing, open-source use, foundation-model restrictions and third-party contractual limitations are documented and monitored.	EU AI Act Art. 9, 11, 12, 15, 72 ISO/IEC 42001 §8/§9 ISO/IEC 27090 model compromise NIST AI RMF MEASURE/MANAGE OWASP LLM05 MITRE ATLAS model theft/inversion CSA

#	Control Name	Core Requirement	Framework Alignment
			AICM model security

It makes Model, Artifact & IP Security measurable at control level rather than leaving it as a broad principle. Each control has a requirement and cross-framework mapping that can be audited and improved. The result is a reproducible maturity score and a clear remediation path for the domain.

9. Domain 6 — LLM, Prompt, RAG & GenAI Application Security

Weight: 10% | Controls: AISCA-46 to AISCA-54 | Prompt injection defence, system prompt protection, input/output validation, RAG authorisation, tool validation and telemetry.

Domain 6 establishes the NS AISCA control layer for LLM, prompt, RAG & GenAI application security. It defines the technical, operational and evidentiary controls that must be implemented for AI systems in scope. The domain is assessed independently, but its maturity also contributes to the overall weighted AISCA score. Controls in this domain should be interpreted in proportion to AI exposure, regulatory obligations, system criticality and target maturity.

Domain 6 control catalogue

This table defines the nine AI security controls that make up LLM, Prompt, RAG & GenAI Application Security. It describes the core requirement and multi-framework alignment for each control so that assessors can score maturity consistently. This is achieved by converting a broad domain objective into specific auditable requirements that can be assigned to owners, evidenced, tested, and remediated. It is used directly in the NS AISCA assessment workbook for current maturity, target maturity, gap calculation, and roadmap priority.

#	Control Name	Core Requirement	Framework Alignment
AISCA-46	Prompt Injection Defence	Prompt injection defence is implemented and tested for direct and indirect manipulation of model instructions, retrieved content, and user inputs.	EU AI Act Art. 13, 15, 50 ISO/IEC 42001 §8/§9 ISO/IEC 27090 GenAI threats NIST AI RMF + AI 600-1 OWASP LLM01/02/04/06/07/10 MITRE ATLAS prompt injection CISA/NCSC secure deployment Google SAIF
AISCA-47	System Prompt and Orchestration Protection	System prompts, hidden instructions, policy prompts, routing rules, and orchestration logic are protected from disclosure, tampering, and unapproved changes.	EU AI Act Art. 13, 15, 50 ISO/IEC 42001 §8/§9 ISO/IEC 27090 GenAI threats NIST AI RMF + AI 600-1 OWASP LLM01/02/04/06/07/10 MITRE ATLAS prompt injection CISA/NCSC secure deployment Google SAIF
AISCA-48	Input Validation for GenAI	Input validation filters malicious, irrelevant, unsafe, policy-violating, or anomalous prompt content before it reaches the model or downstream tools.	EU AI Act Art. 13, 15, 50 ISO/IEC 42001 §8/§9 ISO/IEC 27090 GenAI threats NIST AI RMF + AI 600-1 OWASP LLM01/02/04/06/07/10 MITRE ATLAS prompt injection CISA/NCSC secure deployment Google SAIF
AISCA-49	Output Validation and Response Safety	Output validation prevents unsafe, sensitive, malicious, misleading or non-compliant AI responses from reaching users or downstream systems.	EU AI Act Art. 13, 15, 50 ISO/IEC 42001 §8/§9 ISO/IEC 27090 GenAI threats NIST AI RMF + AI 600-1 OWASP LLM01/02/04/06/07/10 MITRE ATLAS prompt injection CISA/NCSC secure deployment Google SAIF
AISCA-50	RAG Retrieval Authorisation	RAG retrieval enforces user-, document-, source-, and context-level authorisation and prevents	EU AI Act Art. 13, 15, 50 ISO/IEC 42001 §8/§9 ISO/IEC

#	Control Name	Core Requirement	Framework Alignment
		retrieval from bypassing source permissions.	27090 GenAI threats NIST AI RMF + AI 600-1 OWASP LLM01/02/04/06/07/10 MITRE ATLAS prompt injection CISA/NCSC secure deployment Google SAIF
AISCA-51	Context Isolation and Context Poisoning Controls	Context-window controls prevent cross-user leakage, context poisoning, residual instruction carryover and unsafe long-context accumulation.	EU AI Act Art. 13, 15, 50 ISO/IEC 42001 §8/§9 ISO/IEC 27090 GenAI threats NIST AI RMF + AI 600-1 OWASP LLM01/02/04/06/07/10 MITRE ATLAS prompt injection CISA/NCSC secure deployment Google SAIF
AISCA-52	Tool-Call Validation for LLM Applications	Tool-call requests from LLMs are validated before execution against user permissions, tool policy, data sensitivity, action impact, and business purpose.	EU AI Act Art. 13, 15, 50 ISO/IEC 42001 §8/§9 ISO/IEC 27090 GenAI threats NIST AI RMF + AI 600-1 OWASP LLM01/02/04/06/07/10 MITRE ATLAS prompt injection CISA/NCSC secure deployment Google SAIF
AISCA-53	GenAI Abuse, Rate and Cost Controls	GenAI applications enforce rate limits, detect abuse, maintain content boundaries, control costs, and implement safeguards against unbounded consumption.	EU AI Act Art. 13, 15, 50 ISO/IEC 42001 §8/§9 ISO/IEC 27090 GenAI threats NIST AI RMF + AI 600-1 OWASP LLM01/02/04/06/07/10 MITRE ATLAS prompt injection CISA/NCSC secure deployment Google SAIF
AISCA-54	Prompt, Retrieval and Tool Telemetry	Prompt, completion, citation, retrieval, tool use, and policy-decision telemetry are captured for assurance, monitoring, and investigation.	EU AI Act Art. 13, 15, 50 ISO/IEC 42001 §8/§9 ISO/IEC 27090 GenAI threats NIST AI RMF + AI 600-1 OWASP LLM01/02/04/06/07/10 MITRE ATLAS prompt injection CISA/NCSC secure deployment Google SAIF

It makes LLM, Prompt, RAG & GenAI Application Security measurable at control level rather than leaving it as a broad principle. Each control has a requirement and cross-framework mapping that can be audited and improved. The result is a reproducible maturity score and a clear remediation path for the domain.

10. Domain 7 — Agentic AI, Tool & Autonomy Security

Weight: 10% | Controls: AISCA-55 to AISCA-63 | Agent permission scopes, tool registry, approval gates, autonomy limits, memory governance, sandboxing and kill switches.

Domain 7 establishes the NS AISCA control layer for Agentic AI, Tool & Autonomy Security. It defines the technical, operational, and evidentiary controls that must be implemented for AI systems in scope. The domain is assessed independently, but its maturity also contributes to the overall weighted AISCA score. Controls in this domain should be interpreted in proportion to AI exposure, regulatory obligations, system criticality, and target maturity.

Domain 7 control catalogue

This table defines the nine AI security controls that make up Agentic AI, Tool & Autonomy Security. It describes the core requirement and multi-framework alignment for each control so that assessors can score maturity consistently. This is achieved by converting a broad domain objective into specific auditable requirements that

can be assigned to owners, evidenced, tested and remediated. It is used directly in the NS AISCA assessment workbook for current maturity, target maturity, gap calculation and roadmap priority.

#	Control Name	Core Requirement	Framework Alignment
AISCA-55	Agent Permission Scoping	AI agents operate under explicit permission scopes tied to approved business purposes.	EU AI Act Art. 14, 15, 50 ISO/IEC 42001 §8/§9 ISO/IEC 27090 autonomous systems NIST AI RMF MANAGE OWASP LLM06/07/08 MITRE ATLAS agent/tool misuse CSA AICM IAM and application controls
AISCA-56	Tool Registry and Tool Risk Classification	A tool registry defines approved tools, owners, permissions, data handled, allowed actions, risks, and monitoring requirements.	EU AI Act Art. 14, 15, 50 ISO/IEC 42001 §8/§9 ISO/IEC 27090 autonomous systems NIST AI RMF MANAGE OWASP LLM06/07/08 MITRE ATLAS agent/tool misuse CSA AICM IAM and application controls
AISCA-57	Human Approval Gates for High-Impact Actions	High-impact agent actions require human approval or policy-based secondary authorisation before execution.	EU AI Act Art. 14, 15, 50 ISO/IEC 42001 §8/§9 ISO/IEC 27090 autonomous systems NIST AI RMF MANAGE OWASP LLM06/07/08 MITRE ATLAS agent/tool misuse CSA AICM IAM and application controls
AISCA-58	Agent Autonomy Limits	Agent autonomy limits define maximum authority, spending, data access, transaction value, action frequency, time horizon, and permitted execution environment.	EU AI Act Art. 14, 15, 50 ISO/IEC 42001 §8/§9 ISO/IEC 27090 autonomous systems NIST AI RMF MANAGE OWASP LLM06/07/08 MITRE ATLAS agent/tool misuse CSA AICM IAM and application controls
AISCA-59	Agent Memory Governance	Agent memory is governed, classified, scoped, retained, reviewed, and erasable.	EU AI Act Art. 14, 15, 50 ISO/IEC 42001 §8/§9 ISO/IEC 27090 autonomous systems NIST AI RMF MANAGE OWASP LLM06/07/08 MITRE ATLAS agent/tool misuse CSA AICM IAM and application controls
AISCA-60	Agent Credential Security	Agent credentials are short-lived, scoped, rotated, monitored and never embedded in prompts, logs or memory.	EU AI Act Art. 14, 15, 50 ISO/IEC 42001 §8/§9 ISO/IEC 27090 autonomous systems NIST AI RMF MANAGE OWASP LLM06/07/08 MITRE ATLAS agent/tool misuse CSA AICM IAM and application controls
AISCA-61	Multi-Agent Trust Boundaries	Multi-agent systems define trust boundaries, communication rules, escalation paths and inter-agent authorisation.	EU AI Act Art. 14, 15, 50 ISO/IEC 42001 §8/§9 ISO/IEC 27090 autonomous systems NIST AI RMF MANAGE OWASP LLM06/07/08 MITRE ATLAS agent/tool misuse CSA AICM IAM and application controls
AISCA-62	Sandboxed Tool Execution	Agents execute tools in sandboxed environments with constrained network, filesystem, API, identity and transaction access.	EU AI Act Art. 14, 15, 50 ISO/IEC 42001 §8/§9 ISO/IEC 27090 autonomous systems NIST AI RMF MANAGE

#	Control Name	Core Requirement	Framework Alignment
			OWASP LLM06/07/08 MITRE ATLAS agent/tool misuse CSA AICM IAM and application controls
AISCA-63	Agent Kill-Switch and Emergency Containment	Kill-switch, pause, rollback and emergency containment mechanisms exist for autonomous AI workflows.	EU AI Act Art. 14, 15, 50 ISO/IEC 42001 §8/§9 ISO/IEC 27090 autonomous systems NIST AI RMF MANAGE OWASP LLM06/07/08 MITRE ATLAS agent/tool misuse CSA AICM IAM and application controls

It makes Agentic AI, Tool & Autonomy Security measurable at control level rather than leaving it as a broad principle. Each control has a requirement and cross-framework mapping that can be audited and improved. The result is a reproducible maturity score and a clear remediation path for the domain.

11. Domain 8 — MLOps, MLSecOps & AI Supply Chain Security

Weight: 9% | Controls: AISCA-64 to AISCA-72 | Repository security, pipeline gates, supply-chain risk, SBOM/AI-BOM linkage, dependency scanning and reproducibility.

Domain 8 establishes the NS AISCA control layer for MLOps, MLSecOps & AI Supply Chain Security. It defines the technical, operational and evidentiary controls that must be implemented for AI systems in scope. The domain is assessed independently, but its maturity also contributes to the overall weighted AISCA score. Controls in this domain should be interpreted in proportion to AI exposure, regulatory obligations, system criticality and target maturity.

Domain 8 control catalogue

This table defines the nine AI security controls that make up MLOps, MLSecOps & AI Supply Chain Security. It describes the core requirement and multi-framework alignment for each control so that assessors can score maturity consistently. This is achieved by converting a broad domain objective into specific auditable requirements that can be assigned to owners, evidenced, tested and remediated. It is used directly in the NS AISCA assessment workbook for current maturity, target maturity, gap calculation and roadmap priority.

#	Control Name	Core Requirement	Framework Alignment
AISCA-64	AI Repository Security	AI development repositories follow secure coding practices, branch protection, peer review, secrets scanning and protected release branches.	EU AI Act Art. 9, 11, 15, 72 ISO/IEC 42001 §8 ISO/IEC 27001 supplier and development controls ISO/IEC 27090 supply chain NIST SSDF NIST CSF ID/PR OWASP LLM05 CSA AICM supply chain
AISCA-65	MLSecOps Pipeline Gates	CI/CD and MLOps pipelines include gates for code security, dependency risk, dataset approval, model artifact signing, prompt validation and deployment approval.	EU AI Act Art. 9, 11, 15, 72 ISO/IEC 42001 §8 ISO/IEC 27001 supplier and development controls ISO/IEC 27090 supply chain NIST SSDF NIST CSF ID/PR OWASP LLM05 CSA AICM supply chain
AISCA-66	AI Supply-Chain Risk Assessment	AI supply-chain risk assessment covers models, datasets, libraries, APIs, plugins, cloud AI services, vendors, and foundation model providers.	EU AI Act Art. 9, 11, 15, 72 ISO/IEC 42001 §8 ISO/IEC 27001 supplier and development controls ISO/IEC 27090 supply chain NIST SSDF NIST CSF ID/PR OWASP LLM05 CSA AICM

#	Control Name	Core Requirement	Framework Alignment
			supply chain
AISCA-67	SBOM and AI-BOM Linkage	Software and AI bills of materials are maintained and linked for AI-enabled products.	EU AI Act Art. 9, 11, 15, 72 ISO/IEC 42001 §8 ISO/IEC 27001 supplier and development controls ISO/IEC 27090 supply chain NIST SSDF NIST CSF ID/PR OWASP LLM05 CSA AICM supply chain
AISCA-68	Model and Dataset Dependency Scanning	Model and dataset dependencies are scanned for vulnerabilities, malicious packages, provenance issues, poisoned datasets, and licensing risk.	EU AI Act Art. 9, 11, 15, 72 ISO/IEC 42001 §8 ISO/IEC 27001 supplier and development controls ISO/IEC 27090 supply chain NIST SSDF NIST CSF ID/PR OWASP LLM05 CSA AICM supply chain
AISCA-69	Environment Separation	Environment separation prevents uncontrolled movement between development, test, staging and production for code, datasets, prompts, models and agents.	EU AI Act Art. 9, 11, 15, 72 ISO/IEC 42001 §8 ISO/IEC 27001 supplier and development controls ISO/IEC 27090 supply chain NIST SSDF NIST CSF ID/PR OWASP LLM05 CSA AICM supply chain
AISCA-70	Reproducibility and Build Evidence	Reproducibility controls preserve evidence for build, training, tuning, evaluation, and deployment.	EU AI Act Art. 9, 11, 15, 72 ISO/IEC 42001 §8 ISO/IEC 27001 supplier and development controls ISO/IEC 27090 supply chain NIST SSDF NIST CSF ID/PR OWASP LLM05 CSA AICM supply chain
AISCA-71	Foundation-Model Update Review	Foundation-model updates trigger change review, regression testing, prompt and RAG retesting, security reassessment, and vendor risk review.	EU AI Act Art. 9, 11, 15, 72 ISO/IEC 42001 §8 ISO/IEC 27001 supplier and development controls ISO/IEC 27090 supply chain NIST SSDF NIST CSF ID/PR OWASP LLM05 CSA AICM supply chain
AISCA-72	MLOps Administrative Action Logging	MLOps administrative actions are logged, approved, and periodically reviewed.	EU AI Act Art. 9, 11, 15, 72 ISO/IEC 42001 §8 ISO/IEC 27001 supplier and development controls ISO/IEC 27090 supply chain NIST SSDF NIST CSF ID/PR OWASP LLM05 CSA AICM supply chain

It makes MLOps, MLSecOps & AI Supply Chain Security measurable at the control level rather than leaving them as broad principles. Each control has a requirement and cross-framework mapping that can be audited and improved. The result is a reproducible maturity score and a clear remediation path for the domain.

12. Domain 9 — Runtime, Cloud, API & Platform Security

Weight: 8% | Controls: AISCA-73 to AISCA-81 | Workload segmentation, endpoint protection, API security, runtime hardening, secret management, encryption and tenant isolation.

Domain 9 establishes the NS AISCA control layer for runtime, cloud, api & platform security. It defines the technical, operational and evidentiary controls that must be implemented for AI systems in scope. The domain

is assessed independently, but its maturity also contributes to the overall weighted AISCA score. Controls in this domain should be interpreted in proportion to AI exposure, regulatory obligations, system criticality and target maturity.

Domain 9 control catalogue

This table defines the nine AI security controls that make up Runtime, Cloud, API & Platform Security. It describes the core requirement and multi-framework alignment for each control so that assessors can score maturity consistently. This is achieved by converting a broad domain objective into specific auditable requirements that can be assigned to owners, evidenced, tested, and remediated. It is used directly in the NS AISCA assessment workbook for current maturity, target maturity, gap calculation, and roadmap priority.

#	Control Name	Core Requirement	Framework Alignment
AISCA-73	AI Workload Segmentation	AI workloads are segmented from general enterprise workloads based on risk, sensitivity, and exposure.	EU AI Act Art. 15 ISO/IEC 42001 §8/§9 ISO/IEC 27001 access, cryptography, operations ISO/IEC 27090 runtime threats NIST CSF PR/DE OWASP LLM04/10 CSA AICM cloud platform CISA/NCSC operation
AISCA-74	AI Endpoint Protection	AI endpoints are protected by strong authentication, authorisation, throttling, gateway enforcement, input validation and monitoring.	EU AI Act Art. 15 ISO/IEC 42001 §8/§9 ISO/IEC 27001 access, cryptography, operations ISO/IEC 27090 runtime threats NIST CSF PR/DE OWASP LLM04/10 CSA AICM cloud platform CISA/NCSC operation
AISCA-75	AI API Security Controls	AI APIs enforce schema validation, rate limits, anomaly detection, tenant scoping, token validation, abuse controls and model-extraction defences.	EU AI Act Art. 15 ISO/IEC 42001 §8/§9 ISO/IEC 27001 access, cryptography, operations ISO/IEC 27090 runtime threats NIST CSF PR/DE OWASP LLM04/10 CSA AICM cloud platform CISA/NCSC operation
AISCA-76	Secure Inference Runtime Baselines	Inference environments use secure configuration baselines, hardened runtime images, patch management, and runtime isolation.	EU AI Act Art. 15 ISO/IEC 42001 §8/§9 ISO/IEC 27001 access, cryptography, operations ISO/IEC 27090 runtime threats NIST CSF PR/DE OWASP LLM04/10 CSA AICM cloud platform CISA/NCSC operation
AISCA-77	Secrets and Key Management for AI	Secrets, keys, and tokens used by AI systems, agents, pipelines, and tools are stored in approved secret management systems.	EU AI Act Art. 15 ISO/IEC 42001 §8/§9 ISO/IEC 27001 access, cryptography, operations ISO/IEC 27090 runtime threats NIST CSF PR/DE OWASP LLM04/10 CSA AICM cloud platform CISA/NCSC operation
AISCA-78	Encryption for AI Data and Artifacts	Encryption protects AI data, prompts, logs, model artifacts, embeddings, backups, and inference traffic in transit and at rest.	EU AI Act Art. 15 ISO/IEC 42001 §8/§9 ISO/IEC 27001 access, cryptography, operations ISO/IEC 27090 runtime threats NIST CSF PR/DE OWASP LLM04/10 CSA AICM cloud platform CISA/NCSC operation
AISCA-79	Cloud AI Secure Configuration	Cloud AI services are configured according to secure-by-default baselines and monitored for	EU AI Act Art. 15 ISO/IEC 42001 §8/§9 ISO/IEC 27001

#	Control Name	Core Requirement	Framework Alignment
		posture drift.	access, cryptography, operations ISO/IEC 27090 runtime threats NIST CSF PR/DE OWASP LLM04/10 CSA AICM cloud platform CISA/NCSC operation
AISCA-80	Tenant and User Isolation	Tenant isolation prevents cross-customer, cross-user, cross-project, or cross-session leakage of prompts, embeddings, logs, retrieval results, model outputs, and agent memory.	EU AI Act Art. 15 ISO/IEC 42001 §8/§9 ISO/IEC 27001 access, cryptography, operations ISO/IEC 27090 runtime threats NIST CSF PR/DE OWASP LLM04/10 CSA AICM cloud platform CISA/NCSC operation
AISCA-81	Resource Consumption Controls	Resource-consumption controls prevent denial-of-wallet attacks, model denial-of-service attacks, runaway agent execution, and uncontrolled inference costs.	EU AI Act Art. 15 ISO/IEC 42001 §8/§9 ISO/IEC 27001 access, cryptography, operations ISO/IEC 27090 runtime threats NIST CSF PR/DE OWASP LLM04/10 CSA AICM cloud platform CISA/NCSC operation

It makes Runtime, Cloud, API & Platform Security measurable at the control level rather than leaving them as broad principles. Each control has a requirement and cross-framework mapping that can be audited and improved. The result is a reproducible maturity score and a clear remediation path for the domain.

13. Domain 10 — AI Security Monitoring, Logging & Detection

Weight: 8% | Controls: AISCA-82 to AISCA-90 | Security event logging, tamper-evident logs, AI threat detection, drift monitoring, SOC integration and forensic readiness.

Domain 10 establishes the NS AISCA control layer for AI security monitoring, logging & detection. It defines the technical, operational and evidentiary controls that must be implemented for AI systems in scope. The domain is assessed independently, but its maturity also contributes to the overall weighted AISCA score. Controls in this domain should be interpreted in proportion to AI exposure, regulatory obligations, system criticality and target maturity.

Domain 10 control catalogue

This table defines the nine AI security controls that make up AI Security Monitoring, Logging & Detection. It describes the core requirement and multi-framework alignment for each control so that assessors can score maturity consistently. This is achieved by converting a broad domain objective into specific auditable requirements that can be assigned to owners, evidenced, tested, and remediated. It is used directly in the NS AISCA assessment workbook for current maturity, target maturity, gap calculation, and roadmap priority.

#	Control Name	Core Requirement	Framework Alignment
AISCA-82	AI Security Event Logging	AI security logs capture prompts, outputs, model versions, retrieval sources, tool calls, user identities, policy decisions, security events, and administrative actions.	EU AI Act Art. 12, 15, 72 ISO/IEC 42001 §9 ISO/IEC 27001 logging and monitoring ISO/IEC 27090 detection NIST AI RMF MEASURE NIST CSF DE MITRE ATLAS detection CSA AICM monitoring Google SAIF detection
AISCA-83	Tamper-Evident Log Management	Logs are tamper-evident, centrally stored, access-controlled, searchable, and retained in accordance with legal, risk, and forensic requirements.	EU AI Act Art. 12, 15, 72 ISO/IEC 42001 §9 ISO/IEC 27001 logging and monitoring ISO/IEC 27090 detection NIST AI RMF MEASURE NIST CSF

#	Control Name	Core Requirement	Framework Alignment
			DE MITRE ATLAS detection CSA AICM monitoring Google SAIF detection
AISCA-84	AI-Specific Threat Detection	AI-specific detections cover prompt injection, jailbreak attempts, data exfiltration, model extraction, abnormal API use, unsafe tool calls, agent overreach, and suspicious retrieval.	EU AI Act Art. 12, 15, 72 ISO/IEC 42001 §9 ISO/IEC 27001 logging and monitoring ISO/IEC 27090 detection NIST AI RMF MEASURE NIST CSF DE MITRE ATLAS detection CSA AICM monitoring Google SAIF detection
AISCA-85	Model Drift and Behaviour Monitoring	Model performance, drift, degradation, anomalous behaviour and unexpected output patterns are continuously monitored.	EU AI Act Art. 12, 15, 72 ISO/IEC 42001 §9 ISO/IEC 27001 logging and monitoring ISO/IEC 27090 detection NIST AI RMF MEASURE NIST CSF DE MITRE ATLAS detection CSA AICM monitoring Google SAIF detection
AISCA-86	SOC, SIEM and SOAR Integration	AI security alerts are integrated into SOC, SIEM, SOAR, or incident management workflows.	EU AI Act Art. 12, 15, 72 ISO/IEC 42001 §9 ISO/IEC 27001 logging and monitoring ISO/IEC 27090 detection NIST AI RMF MEASURE NIST CSF DE MITRE ATLAS detection CSA AICM monitoring Google SAIF detection
AISCA-87	AI Security KRIs	AI KRIs track security posture, incidents, high-risk gaps, prompt attacks, agent exceptions, policy violations, remediation ageing and evidence expiry.	EU AI Act Art. 12, 15, 72 ISO/IEC 42001 §9 ISO/IEC 27001 logging and monitoring ISO/IEC 27090 detection NIST AI RMF MEASURE NIST CSF DE MITRE ATLAS detection CSA AICM monitoring Google SAIF detection
AISCA-88	Production Safety and Security Monitoring Linkage	Production fairness, safety and security monitoring are linked to escalation paths and incident triggers.	EU AI Act Art. 12, 15, 72 ISO/IEC 42001 §9 ISO/IEC 27001 logging and monitoring ISO/IEC 27090 detection NIST AI RMF MEASURE NIST CSF DE MITRE ATLAS detection CSA AICM monitoring Google SAIF detection
AISCA-89	Threat Intelligence-Driven Detection Updates	Detection logic is updated as AI threat intelligence, MITRE ATLAS techniques, OWASP guidance, vendor advisories, and incident learnings change.	EU AI Act Art. 12, 15, 72 ISO/IEC 42001 §9 ISO/IEC 27001 logging and monitoring ISO/IEC 27090 detection NIST AI RMF MEASURE NIST CSF DE MITRE ATLAS detection CSA AICM monitoring Google SAIF detection
AISCA-90	Forensic and Regulatory Evidence Readiness	Monitoring evidence supports audit, regulatory enquiry, legal review and forensic investigation.	EU AI Act Art. 12, 15, 72 ISO/IEC 42001 §9 ISO/IEC 27001 logging and monitoring ISO/IEC 27090 detection NIST AI RMF MEASURE NIST CSF DE MITRE ATLAS detection CSA AICM monitoring Google SAIF detection

It makes AI security monitoring, logging & detection measurable at control level rather than leaving it as a broad principle. Each control has a requirement and cross-framework mapping that can be audited and improved. The result is a reproducible maturity score and a clear remediation path for the domain.

14. Domain 11 — AI Assurance, Red Teaming & Independent Validation

Weight: 7% | Controls: AISCA-91 to AISCA-99 | Security test plans, adversarial testing, LLM and agent red teaming, regression testing and independent validation.

Domain 11 establishes the NS AISCA control layer for AI assurance, red teaming & independent validation. It defines the technical, operational and evidentiary controls that must be implemented for AI systems in scope. The domain is assessed independently, but its maturity also contributes to the overall weighted AISCA score. Controls in this domain should be interpreted in proportion to AI exposure, regulatory obligations, system criticality and target maturity.

Domain 11 control catalogue

This table defines the nine AI security controls that make up AI Assurance, Red Teaming & Independent Validation. It describes the core requirement and multi-framework alignment for each control so that assessors can score maturity consistently. This is achieved by converting a broad domain objective into specific auditable requirements that can be assigned to owners, evidenced, tested, and remediated. It is used directly in the NS AISCA assessment workbook for current maturity, target maturity, gap calculation, and roadmap priority.

#	Control Name	Core Requirement	Framework Alignment
AISCA-91	AI Security Test Plans	AI security test plans are required before production release and after material change.	EU AI Act Art. 9, 15, 43 ISO/IEC 42001 §9 ISO/IEC 23894 evaluation ISO/IEC 27090 assurance NIST AI RMF MEASURE/MANAGE OWASP testing guidance MITRE ATLAS Microsoft AI Red Team CISA/NCSC development
AISCA-92	Adversarial ML Testing	Adversarial testing assesses model manipulation, evasion, poisoning, extraction, inversion, membership inference, privacy leakage and unsafe behaviour.	EU AI Act Art. 9, 15, 43 ISO/IEC 42001 §9 ISO/IEC 23894 evaluation ISO/IEC 27090 assurance NIST AI RMF MEASURE/MANAGE OWASP testing guidance MITRE ATLAS Microsoft AI Red Team CISA/NCSC development
AISCA-93	LLM Red Teaming	LLM red teaming assesses jailbreaks, direct and indirect prompt injection, sensitive disclosure, tool misuse, system-prompt leakage, policy bypass, and unbounded consumption.	EU AI Act Art. 9, 15, 43 ISO/IEC 42001 §9 ISO/IEC 23894 evaluation ISO/IEC 27090 assurance NIST AI RMF MEASURE/MANAGE OWASP testing guidance MITRE ATLAS Microsoft AI Red Team CISA/NCSC development
AISCA-94	Agentic AI Red Teaming	Agentic red teaming assesses excessive agency, unsafe tool use, memory abuse, credential exposure, autonomy-limit bypass, inter-agent trust exploitation, and containment failure.	EU AI Act Art. 9, 15, 43 ISO/IEC 42001 §9 ISO/IEC 23894 evaluation ISO/IEC 27090 assurance NIST AI RMF MEASURE/MANAGE OWASP testing guidance MITRE ATLAS Microsoft AI Red Team CISA/NCSC development
AISCA-95	AI Security Regression Testing	Regression testing confirms that security controls continue to operate following changes to the model, prompt, data, RAG, tool, pipeline, vendor, or configuration.	EU AI Act Art. 9, 15, 43 ISO/IEC 42001 §9 ISO/IEC 23894 evaluation ISO/IEC 27090 assurance NIST AI RMF

#	Control Name	Core Requirement	Framework Alignment
			MEASURE/MANAGE OWASP testing guidance MITRE ATLAS Microsoft AI Red Team CISA/NCSC development
AISCA-96	Independent Validation	Independent validation is required for high-risk, externally exposed, mission-critical or regulated AI systems.	EU AI Act Art. 9, 15, 43 ISO/IEC 42001 §9 ISO/IEC 23894 evaluation ISO/IEC 27090 assurance NIST AI RMF MEASURE/MANAGE OWASP testing guidance MITRE ATLAS Microsoft AI Red Team CISA/NCSC development
AISCA-97	Risk-Ranked Security Findings	Security findings are risk-ranked by exploitability, impact, exposure, autonomy, data sensitivity and regulatory consequences.	EU AI Act Art. 9, 15, 43 ISO/IEC 42001 §9 ISO/IEC 23894 evaluation ISO/IEC 27090 assurance NIST AI RMF MEASURE/MANAGE OWASP testing guidance MITRE ATLAS Microsoft AI Red Team CISA/NCSC development
AISCA-98	Assurance Evidence Register	Assurance evidence is stored in an evidence register with control mapping, owner, version, date, expiry, retest requirement and status.	EU AI Act Art. 9, 15, 43 ISO/IEC 42001 §9 ISO/IEC 23894 evaluation ISO/IEC 27090 assurance NIST AI RMF MEASURE/MANAGE OWASP testing guidance MITRE ATLAS Microsoft AI Red Team CISA/NCSC development
AISCA-99	Residual Risk Acceptance	Residual risk is formally accepted before release when material AI security weaknesses remain.	EU AI Act Art. 9, 15, 43 ISO/IEC 42001 §9 ISO/IEC 23894 evaluation ISO/IEC 27090 assurance NIST AI RMF MEASURE/MANAGE OWASP testing guidance MITRE ATLAS Microsoft AI Red Team CISA/NCSC development

It makes AI Assurance, Red Teaming & Independent Validation measurable at the control level rather than leaving them as broad principles. Each control has a requirement and cross-framework mapping that can be audited and improved. The result is a reproducible maturity score and a clear remediation path for the domain.

15. Domain 12 — AI Incident Response, Resilience & Continuous Compliance

Weight: 5% | Controls: AISCA-100 to AISCA-108 | AI incident playbooks, severity criteria, reporting triggers, emergency containment, continuity and reassessment.

Domain 12 establishes the NS AISCA control layer for AI incident response, resilience & continuous compliance. It defines the technical, operational and evidentiary controls that must be implemented for AI systems in scope. The domain is assessed independently, but its maturity also contributes to the overall weighted AISCA score. Controls in this domain should be interpreted in proportion to AI exposure, regulatory obligations, system criticality and target maturity.

Domain 12 control catalogue

This table defines the nine AI security controls that make up AI Incident Response, Resilience & Continuous Compliance. It describes the core requirement and multi-framework alignment for each control so that assessors can score maturity consistently. This is achieved by converting a broad domain objective into specific

auditable requirements that can be assigned to owners, evidenced, tested, and remediated. It is used directly in the NS AISCA assessment workbook for current maturity, target maturity, gap calculation, and roadmap priority.

#	Control Name	Core Requirement	Framework Alignment
AISCA-100	AI Incident Response Playbooks	AI-specific incident response playbooks cover model compromise, prompt attacks, data leakage, unsafe outputs, agent misuse, model drift, vendor incidents, and AI service outages.	EU AI Act Art. 12, 15, 72, 73 ISO/IEC 42001 §10 ISO/IEC 27001 incident and continuity ISO/IEC 27090 response NIST AI RMF MANAGE NIST CSF RS/RC CSA AICM incident management CISA/NCSC maintenance
AISCA-101	AI Incident Severity Criteria	AI incidents are assessed for severity based on safety, rights, confidentiality, integrity, availability, autonomy, model integrity, financial impact, and regulatory exposure.	EU AI Act Art. 12, 15, 72, 73 ISO/IEC 42001 §10 ISO/IEC 27001 incident and continuity ISO/IEC 27090 response NIST AI RMF MANAGE NIST CSF RS/RC CSA AICM incident management CISA/NCSC maintenance
AISCA-102	Regulatory and Contractual Reporting Triggers	Regulatory reporting triggers are mapped to applicable laws and contracts, including EU AI Act serious-incident reporting, data protection notifications, and customer reporting.	EU AI Act Art. 12, 15, 72, 73 ISO/IEC 42001 §10 ISO/IEC 27001 incident and continuity ISO/IEC 27090 response NIST AI RMF MANAGE NIST CSF RS/RC CSA AICM incident management CISA/NCSC maintenance
AISCA-103	Emergency Rollback, Freeze and Shutdown	Model rollback, version freeze, access revocation, agent pause, and emergency shutdown procedures are tested on compromised, unsafe, or non-compliant AI systems.	EU AI Act Art. 12, 15, 72, 73 ISO/IEC 42001 §10 ISO/IEC 27001 incident and continuity ISO/IEC 27090 response NIST AI RMF MANAGE NIST CSF RS/RC CSA AICM incident management CISA/NCSC maintenance
AISCA-104	Post-Incident Review and Control Improvement	Post-incident reviews identify root causes, control failures, evidence gaps, decision failures, and required architectural changes.	EU AI Act Art. 12, 15, 72, 73 ISO/IEC 42001 §10 ISO/IEC 27001 incident and continuity ISO/IEC 27090 response NIST AI RMF MANAGE NIST CSF RS/RC CSA AICM incident management CISA/NCSC maintenance
AISCA-105	AI Continuity and Degraded-Mode Operations	Business continuity plans address AI dependency, model unavailability, vendor outages, corrupted model behaviour, API failures, and degraded-mode operations.	EU AI Act Art. 12, 15, 72, 73 ISO/IEC 42001 §10 ISO/IEC 27001 incident and continuity ISO/IEC 27090 response NIST AI RMF MANAGE NIST CSF RS/RC CSA AICM incident management CISA/NCSC maintenance
AISCA-106	Third-Party AI Incident Integration	Third-party AI provider incidents are contractually reportable and operationally integrated into response plans.	EU AI Act Art. 12, 15, 72, 73 ISO/IEC 42001 §10 ISO/IEC 27001 incident and continuity ISO/IEC 27090 response NIST AI RMF MANAGE NIST CSF RS/RC CSA AICM incident management CISA/NCSC maintenance
AISCA-107	Continuous Regulatory and Threat Compliance	Continuous compliance tracks changes in AI law, standards, threat intelligence, model-provider terms and sector-specific obligations.	EU AI Act Art. 12, 15, 72, 73 ISO/IEC 42001 §10 ISO/IEC 27001 incident and continuity ISO/IEC 27090 response NIST

#	Control Name	Core Requirement	Framework Alignment
			AI RMF MANAGE NIST CSF RS/RC CSA AICM incident management CISA/NCSC maintenance
AISCA-108	Quarterly and Annual Reassessment	Quarterly or annual reassessment measures maturity progression, evidence freshness, control effectiveness, and roadmap completion.	EU AI Act Art. 12, 15, 72, 73 ISO/IEC 42001 §10 ISO/IEC 27001 incident and continuity ISO/IEC 27090 response NIST AI RMF MANAGE NIST CSF RS/RC CSA AICM incident management CISA/NCSC maintenance

It makes AI Incident Response, Resilience & Continuous Compliance measurable at the control level rather than leaving them as broad principles. Each control has a requirement and cross-framework mapping that can be audited and improved. The result is a reproducible maturity score and a clear remediation path for the domain.

16. The Maturity Measurement Model: L1 to L5

The NS AISCA maturity model measures how well AI security controls operate under real-world conditions. Maturity depends on implementation depth, consistency, evidence quality, automation, monitoring, and the ability to adapt to changing AI threats. Each control is assessed from L1 to L5, and the selected level must be supported by evidence of the required grade.

The NS AISCA maturity model

This table defines the five maturity levels used to score all 108 controls. It explains what each level means, what process state exists, what evidence quality is expected, how monitoring operates, and what risk posture remains. This is achieved by assigning numerical values from 1 to 5 for use in domain averages and the weighted overall score. Assessors use it to ensure scoring is based on operating reality rather than optimism or documentation volume.

Level	Name and State	Process Definition	Evidence Quality	Monitoring Approach	Risk Posture
L1	Initial — Ad Hoc	No defined control; AI security is absent, inconsistent, or reactive.	No structured evidence.	Issues discovered after incidents.	Very High / Exposed
L2	Managed — Basic	Manual control exists but is people-dependent and inconsistent.	Manual evidence.	Periodic manual checks.	High / Partial
L3	Defined — Enterprise	Formal, repeatable and owner-assigned control across in-scope AI systems.	Structured evidence.	Scheduled monitoring.	Medium / Controlled
L4	Quantitative — Automated	Control is automated, measured and integrated into tools or pipelines.	System-generated evidence.	Continuous monitoring.	Low / Assured
L5	Optimizing — Adaptive	Control is threat-intelligence-driven, continuously validated and self-improving.	Adaptive evidence.	Predictive monitoring.	Very Low / Leading

It defines a consistent maturity language across stakeholders. It distinguishes intention, operation, automation and adaptive assurance. The result is a defensible score that reflects how AI security controls actually perform.

The evidence-grade maturity standard

This table defines the five evidence grades that constrain attainable maturity. It shows what evidence type is required to support each maturity level and prevents high scores from being awarded on unverified assertions. This table works as a gating mechanism for maturity: informal evidence supports low maturity, while system-generated and adaptive evidence support higher maturity. It is used during evidence review, control scoring, audit preparation, and remediation planning.

Grade	Type	Examples	Maturity Constraint
E1	Informal	Meeting notes, verbal statements, informal owner descriptions.	Does not support L3 or above.
E2	Manual	Policies, spreadsheets, manual risk reviews, manual checklists, and manual test results.	Supports L2 where consistently applied.
E3	Structured	Approved procedures, assigned owners, architecture diagrams, tickets, and formal reviews.	Required for L3.
E4	System-generated	SIEM events, CI/CD logs, signed registries, automated scan reports, and immutable logs.	Required for L4.
E5	Adaptive / Continuous	Continuous control validation, detection tuning, automated quarantine and threat-led retesting.	Required for L5.

Maturity without evidence is not defensible under audit or regulatory scrutiny. Evidence quality becomes a hard constraint and not an afterthought. The result is stronger accountability, more reliable scoring and continuous audit readiness.

17. Scoring Methodology & Weighted Domain Architecture

NS AISCA scoring is transparent, reproducible, and explainable. Scores are calculated from control ratings, domain averages, and weighted domain contributions. Priority scoring then converts maturity gaps into a roadmap that surfaces the highest-impact remediation actions first.

The NS AISCA scoring process

This table defines how individual control ratings are converted into domain scores and an overall AISCA maturity score. It explains what is calculated at each step and what output is produced for the workbook and board report. This is achieved by converting L1-L5 selections into numeric scores, averaging applicable controls, multiplying domain scores by weights, and mapping the result to maturity and posture. It is used to make the NS AISCA scoring sufficiently transparent for independent review.

Step	Calculation	Output	Formula
1 — Control Rating	Each control is assessed against L1-L5 maturity criteria with evidence constraints.	Per-control level and score.	L1=1, L2=2, L3=3, L4=4, L5=5.
2 — Control Scoping	Controls not applicable to the AI operating context can be scoped out with justification.	Applicable control set.	Only in-scope controls are averaged.
3 — Domain Scoring	The average is calculated from applicable controls in each domain.	Domain score 1.0–5.0.	Domain Score = AVERAGE(in-scope scores).
4 — Weighted Overall	Each domain score is multiplied by its assigned domain weight and summed.	Overall AISCA score 1.0–5.0.	Overall = $\sum(\text{Domain Score} \times \text{Domain Weight})$.
5 — Readiness and Priority	Overall score maps to readiness percentage; gaps are multiplied by weight.	Readiness %, posture, and roadmap priority.	Readiness = $\text{Overall}/5 \times 100\%$; Priority = $\text{Gap} \times \text{Weight}$.

It turns control judgement into a verifiable scoring model. Assessors and executives can trace any score back to specific controls and evidence. The result is investment-grade AI security measurement that supports board oversight.

The AISCA assurance posture levels

This table defines how the numerical AISCA score translates into a named AI security posture. It tells executives what the score means in practical terms and what action is expected at each level. This is achieved by mapping score ranges to posture labels, readiness signals and recommended next actions. It is used in board reports, client communications, programme planning and maturity target setting.

Score Range	Posture	Name	Meaning and Action
4.50–5.00	AISCA-5	Optimizing / Adaptive	AI security is continuously validated, threat-intelligence-driven and self-improving. Sustain and red-team regularly.
3.50–4.49	AISCA-4	Quantitative / Assured	AI security controls are automated, measured and supported by system-generated evidence. Expand automation.
2.50–3.49	AISCA-3	Defined / Controlled	Formal controls are evidenced and repeatable. Target L4 for high-risk and external-facing AI.
1.50–2.49	AISCA-2	Managed / Developing	Basic manual controls are in place, but coverage and evidence remain inconsistent. Fund remediation.
1.00–1.49	AISCA-1	Initial / Exposed	AI security is ad hoc or absent. Contain or halt high-risk AI pending review.

Numerical scores alone are not sufficient for governance decisions. It translates technical maturity into a posture signal executives can understand quickly. The result is clearer prioritisation, faster funding decisions and stronger accountability.

18. The NS AISCA Scoping Mechanism

NS AISCA uses a scoping mechanism to determine applicable controls, target maturity, and assessment priorities based on the AI estate, regulatory exposure, data sensitivity, autonomy, external exposure, and vendor dependency. Conservative defaults apply: when applicability is uncertain, the control remains in scope until evidence supports exclusion.

The organisational scoping questionnaire

This table defines the organisational profile inputs used to tailor an NS AISCA assessment and identifies which categories determine control applicability and target maturity across the 12 domains. This is achieved by using questionnaire responses to trigger domains, controls, evidence requirements, and architectural patterns. It is used at the beginning of an engagement to prevent over-scoping and under-scoping.

Category	Questions	Control Applicability Determination
Regulatory and Jurisdiction	EU/EEA exposure, sector regulation, data protection, and external audit.	Triggers regulatory mapping, reporting, high-risk inventory, documentation, and continuous compliance controls.
AI Development and Product Posture	Internal development, fine-tuning, AI-enabled product or foundation-model usage.	Triggers model security, artifact integrity, MLSecOps, AI-BOM, fine-tuning, and supply chain controls.
AI Deployment and Exposure	Internal AI, customer-facing AI, public API, RAG or GenAI.	Triggers GenAI security, endpoint protection, RAG authorisation, telemetry and monitoring.
Data and Privacy Profile	Personal data, sensitive data, proprietary knowledge, vector stores or embeddings.	Triggers data lineage, minimisation, vector authorisation, DLP, retention and exfiltration controls.
Autonomy and Agentic AI	Tool use, autonomous action and financial, legal, operational or customer-impacting actions.	Triggers agent permissions, tool registry, approval gates, autonomy limits, sandboxing and kill switches.
Assurance and Incident Exposure	High-risk, mission-critical, external-facing or vendor-dependent AI.	Triggers red teaming, independent validation, incident playbooks, regulatory reporting and reassessment.

AI security assessments must reflect actual operating context. Scoping keeps the assessment rigorous while avoiding irrelevant control burden. The result is a fairer maturity score and a more focused roadmap.

The scoping override mechanism

This table defines how assessors can adjust automatic scoping decisions and explains what each override option does and when to use it. This is achieved by allowing controls to remain automatically scoped, be force-included, or be excluded with documented justification. It is used to preserve assessor judgement while maintaining auditability.

Override Selection	Effect	Use Case
Blank / Auto	Auto-scoping applies based on questionnaire answers.	Use for most controls where the questionnaire accurately reflects applicability.
Apply	Forces the control into scope regardless of automatic logic.	Use when conservative practice, future deployment, or client-specific risk requires assessment.
Exclude	Removes the control from scope with documented justification.	Use only when evidence shows the control is genuinely not applicable or covered by an equivalent mechanism.

Scoping decisions materially affect the maturity score. Every override is visible, intentional and evidence-backed. The result is greater trust in assessment outcomes and fewer disputes over their applicability.

19. The NS AISCA Assessment Workbook and Operating Tool

The NS AISCA Assessment Workbook is the operational delivery vehicle for the framework. It translates the 108-control model into a structured assessment environment with domain sheets, dropdown scoring, evidence capture, automated gap calculation, standards mapping, board reporting, architecture-pattern assessment and a prioritised roadmap.

The assessment workbook module architecture

This table defines the functional architecture of the NS AISCA assessment tool and explains what each module does and what outputs it produces for assessors, client teams and executives. This is achieved by linking assessment inputs to dashboards, roadmaps, evidence registers, mapping matrices, board reports and assurance activities. It shows how the framework becomes operational in a repeatable assessment and reassessment process.

Module	Function	Key Outputs
Scoping Sheet	Captures organisational profile and determines applicable controls.	Scope summary, applicable controls, target domains and assessment boundaries.
Domain Assessment Sheets (×12)	One sheet per domain with controls, maturity inputs, evidence, targets, gaps and status.	Control scores, domain averages, target maturity and owner accountability.
Dashboard	Summarises current vs target maturity, weighted scores, readiness and priority domains.	AISCA score, domain scorecard, heatmap and maturity trend.
Evidence Register	Centralised evidence lifecycle register with owner, type, date, expiry and status.	Audit-ready evidence pack and alerts for expired evidence.
Roadmap	Prioritises remediation based on gap and domain weights.	108-control improvement plan with owner, effort, quarter and status.
Standards Mapping Matrix	Maps controls to EU AI Act, ISO, NIST, OWASP, MITRE, CSA, CISA/NCSC and SAIF.	Cross-framework compliance visibility and evidence traceability.
Board Report	Translates control results into executive posture, top risks, and required decisions.	Board-ready AI security posture report.
Architecture Patterns	Assesses secure chatbot, RAG, AI API, agent, MLSecOps, fine-tuning and foundation-model patterns.	Pattern compliance, design gaps and production-readiness evidence.
Assurance Playbook	Documents threat modelling, red teaming, adversarial testing and incident exercises.	Assurance schedule, findings and reassessment triggers.

It shows how NS AISCA moves from framework language to operational tooling. Workbook outputs are generated from structured assessment inputs. The result is faster assessment delivery, stronger evidence traceability and repeatable continuous improvement.

The domain sheet column architecture

This table defines the standard structure used in every domain assessment sheet. It explains what information is captured for each control and whether each field is static, manual, or formula-driven. This is achieved by giving each control a consistent structure for description, evidence, maturity, target, gap, recommendation, alignment, ownership, and status. Assessors use it to score controls consistently across all domains.

Column	Content	Type	Purpose
A	Control ID	Static	Unique control identifier from AISCA-01 to AISCA-108.
B	Control Name	Static	Short control label identifying the AI security requirement.
C	Control Description	Static	Operational requirement statement for the control.
D	Guidance	Static	Implementation and maturity guidance specific to the control.
E	Assessment Input	Manual	Assessor description of current-state implementation.
F	Supporting Evidence	Manual	Evidence artefacts, logs, reports or tool outputs.
G	Current Rating	Dropdown	Selected maturity level from L1 to L5.
H	Current Score	Formula	Numeric score derived from current rating.
I	Target Rating	Dropdown	Target maturity level.
J	Target Score	Formula	Numeric score derived from target rating.
K	Gap	Formula	Target score minus current score.
L	Recommendation	Formula	Control-specific remediation recommendation.
M	Framework Alignment	Static	Cross-framework mapping to standards and regulations.
N	Override	Dropdown	Auto, Apply or Exclude scoping override.
O	In Scope	Formula	Applicability status after scoping and override logic.
P	Control Owner	Manual	Named owner accountable for operation and evidence.
Q	Compliance Status	Formula	RAG status derived from maturity and scope.

Consistency of assessment structure makes scoring reproducible. Every control captures the same minimum information required for audit and reporting. The result is a workbook that supports baseline assessment, reassessment, and maturity tracking.

20. Standards Mapping Matrix

NS AISCA is mapped to AI security, AI governance, AI risk, secure development, cloud security, and adversarial AI references. The mapping does not convert NS AISCA into a legal opinion or certification guarantee. It provides traceability, enabling a single implementation to support multiple overlapping obligations and assurance questions.

The standards mapping matrix

This table defines the external sources NS AISCA uses for control alignment and explains what each source contributes to AI security and which NS AISCA domains it most strongly informs. This is achieved by linking recognised standards, regulations and guidance documents to relevant security control areas. It is used to support compliance mapping, audit evidence preparation and control library maintenance.

Standard / Framework	Role in NS AISCA	Primary Domain Coverage
EU AI Act / Regulation 2024/1689	Legal obligations for risk management, logging, documentation, human oversight, transparency, cybersecurity, monitoring and incident reporting.	D1-D12, especially D2, D3, D4, D6, D10, D12
EU GPAI Code of Practice	Safety and security practices for general-purpose AI and systemic-risk models.	D5, D6, D8, D11, D12
ISO/IEC 42001:2023	AI Management System requirements for governance, planning, operation, monitoring, audit and improvement.	D1, D2, D3, D8, D10, D11, D12
ISO/IEC 23894:2023	AI risk-management guidance for identifying, analysing, evaluating, treating and monitoring AI risks.	D1, D2, D3, D10, D11
ISO/IEC 27001:2022	Information security baseline for access, cryptography, supplier risk, development, monitoring and incident response.	D1, D4, D8, D9, D10, D12
ISO/IEC 27090	AI cybersecurity guidance for AI-specific threats and compromises across the lifecycle.	All domains, especially D3-D12
NIST AI RMF 1.0	GOVERN, MAP, MEASURE and MANAGE structure for AI risk management.	All domains
NIST AI 600-1 GenAI Profile	GenAI profile for NIST AI RMF and GenAI risk-management actions.	D6, D7, D10, D11
NIST CSF 2.0	Cybersecurity lifecycle functions: Govern, Identify, Protect, Detect, Respond and Recover.	D1, D2, D8, D9, D10, D12
NIST SP 800-218 SSDF	Secure software development framework for AI applications, APIs and MLOps pipelines.	D3, D8
OWASP LLM Top 10 2025	GenAI application risks including prompt injection, data poisoning, supply chain, disclosure and excessive agency.	D4, D6, D7, D8, D9, D11
MITRE ATLAS	Adversary tactics and techniques for AI threat modelling, detection and red teaming.	D3-D7, D10, D11
CSA AI Controls Matrix	Cloud AI security controls and cloud AI assurance expectations.	D2, D8, D9, D10, D12
CISA / NSA / NCSC Secure AI Guidelines	Secure AI lifecycle guidance across design, development, deployment, operation and maintenance.	D3, D8, D9, D10, D12
Google SAIF	Secure AI framework for foundations, detection/response, automation, control harmonisation and contextual risk.	D1, D3, D8, D9, D10, D11
Microsoft AI Red Team Guidance	AI red-team methods for LLMs, GenAI systems and assurance.	D6, D7, D11
ETSI SAI	European AI security standardisation addressing threats to and from AI systems.	D3, D5, D6, D8, D10, D11
OECD AI Principles	Trustworthy AI principles covering safety, accountability, privacy, IP, information integrity and human-centred values.	D1, D3, D4, D5, D12

It demonstrates that NS AISCA is connected to the global AI security ecosystem. One control implementation can generate evidence for several overlapping frameworks. The result is reduced compliance fragmentation and stronger assurance across legal, technical and operational audiences.

21. Technical Architecture Patterns

NS AISCA defines secure reference architecture patterns for common AI deployment scenarios. These patterns translate the control catalogue into concrete design expectations and serve as design gates, assessment references, and remediation targets.

The technical architecture patterns

This table defines minimum secure architecture expectations for common AI system types, and it describes what each pattern must include before production or external exposure. This is achieved by translating the 108 controls into scenario-specific design requirements. It is used during secure design review, threat modelling, launch approval and architecture gap analysis.

Pattern	Minimum Security Architecture Requirements
Secure Chatbot	Identity-aware access, prompt injection defence, input/output validation, rate limits, abuse detection, telemetry, escalation, content-policy enforcement and session isolation.
Secure RAG System	Source provenance, document-level authorisation, vector database access controls, context isolation, citation governance, retrieval logging and leakage prevention.
Secure AI API	Strong authentication and authorisation, schema validation, rate limits, anomaly detection, model extraction controls, tenant isolation and audit logging.
Secure Autonomous Agent	Permission scoping, tool registry, approval gates, autonomy limits, memory governance, sandboxed execution, credential controls and kill-switch mechanisms.
Secure MLSecOps Pipeline	Branch protection, secrets scanning, pipeline integrity gates, dependency scanning, signed artifacts, environment separation and reproducibility.
Secure Fine-Tuning	Dataset approval, lineage verification, privacy impact review, poisoning detection, change-control gates, regression testing and rollback capability.
Secure Third-Party Foundation Model	Vendor due diligence, data-transfer controls, retention review, tenant isolation verification, contract clauses, incident notification and update-risk review.

AI security must be designed into architecture before production release. Teams can apply proven patterns instead of inventing controls for each project. The result is faster, more secure delivery, fewer design omissions, and stronger production readiness.

22. The NS AISCA Assurance Playbook

NS AISCA treats assurance as a continuous programme of threat modelling, design review, adversarial testing, red teaming, evidence review, incident exercising and reassessment. The assurance playbook ensures AI security evidence remains current as systems and threats change.

The assurance playbook activities

This table defines recurring assurance activities used to validate NS AISCA controls and describes what each activity does and how it operates within the AI security lifecycle. This is achieved by connecting control implementation to independent evidence, test results, incident readiness and maturity reassessment. It is used to plan assurance activities, validate target maturity and maintain confidence between full assessments.

Assurance Activity	Operating Method
AI Threat Modelling	Mandatory before design approval and after material change; covers assets, actors, trust boundaries, abuse cases, attack paths and residual risk.
Secure Architecture Review	Confirms reference pattern alignment, identity design, retrieval authorisation, tool controls, logging, containment and monitoring.
Adversarial ML Testing	Tests evasion, poisoning, model extraction, inversion, membership inference, privacy leakage and unsafe behaviour.
LLM Red Teaming	Assesses jailbreaks, prompt injection, sensitive disclosure, system-prompt leakage, tool misuse, policy bypass and unbounded consumption.
Agentic Red Teaming	Tests excessive agency, unsafe tool use, memory abuse, credential exposure, autonomy-limit bypass and containment failure.
Evidence Review	Verifies maturity ratings against evidence grade, recency, ownership, completeness and operating effectiveness.

Assurance Activity	Operating Method
AI Incident Exercise	Validates response to model compromise, prompt attack, data leakage, unsafe output, agent misuse, vendor failure and drift.
Continuous Reassessment	Quarterly for high-risk AI portfolios and annually across the AI estate; updates scores, evidence, mappings and roadmap priorities.

AI security cannot be trusted unless it is tested under realistic conditions. Assurance becomes repeatable, evidence-driven and linked to control maturity. The result is stronger resilience, better incident readiness and more credible board and regulatory reporting.

23. Board Reporting Model

The NS AISCA board report translates technical AI security controls into a business-risk posture. It summarises maturity, high-risk systems, top risks, control failures, remediation status, assurance performed and decisions required.

The board reporting model

This table defines the minimum content of an NS AISCA board report and explains what information must be elevated from technical assessment results to executive oversight. This is achieved by converting scores, evidence status, incidents, and roadmap gaps into governance decision categories. It is used to produce quarterly and annual board-ready AI security posture reporting.

Board View	Content
Executive Posture	Overall current AISCA score, target maturity, readiness percentage, posture level and trend.
High-Risk AI Systems	Named high-risk systems, critical dependencies, externally exposed agents, sensitive-data systems and third-party model consumption.
Top Risks	Material gaps, priority domain weaknesses, repeat incidents, residual risks and emerging AI threat exposure.
Control Failures	Controls below L3, failed assurance tests, expired evidence, overdue remediation and open exceptions.
Remediation Roadmap	Prioritised actions with owner, target quarter, effort, dependencies and status.
Assurance Performed	Threat models, red-team assessments, adversarial tests, incident exercises and independent validation completed.
Decisions Required	Risk acceptance, funding decisions, launch approvals, vendor restrictions, scope changes and target-maturity investments.

Board oversight requires decision-ready information rather than raw technical detail. AI security posture becomes visible, comparable and actionable at executive level. The result is better funding decisions, stronger accountability and faster remediation of high-risk AI exposure.

24. Target Maturity by Organisation Profile

NS AISCA recognises that not every organisation requires the same target maturity for every domain. However, L3 is the minimum defensible baseline for production AI, while higher-risk contexts should target L4 or L5 in priority domains.

The target maturity by organisation profile

This defines recommended NS AISCA targets for different organisation profiles and shows the minimum target maturity and priority domains for each profile based on regulatory, operational and technical exposure. This is achieved by using organisation type and AI risk profile to guide roadmap planning and investment prioritisation. It is used during target-setting workshops and annual maturity planning.

Organisation Profile	Minimum Target	Priority Domains	Rationale
General Enterprise	L3 all domains	D2, D6, D10	L3 across all domains is the minimum defensible baseline for production AI security.
AI-Native Software Vendor / SaaS	L3 all; L4 D6, D7, D8	D6, D7, D8	Customers increasingly require prompt security, supply chain evidence, and MLSecOps maturity.
EU Market / AI Act Scope	L3 all; L4 D3, D4, D5, D6, D10	D3, D4, D5, D6, D10	Risk management, documentation, logging, human oversight, cybersecurity and monitoring are regulatory priorities.
Financial Services	L3+ all; L4 D9, D10, D12	D9, D10, D12	Operational resilience, incident response, third-party risk and secure runtime controls are critical.
Critical Infrastructure	L3+ all; L4 D3, D7, D10, D11	D3, D7, D10, D11	High-impact systems require secure design, autonomy containment, monitoring and validation.
Autonomous / Agentic AI Product	L4 D6, D7, D10, D11	D6, D7, D10, D11	Autonomous action scope, tool use, memory, containment and red-team validation are mission-critical.

Maturity targets must reflect real AI exposure. Organisations can set credible targets aligned with risk and regulation. The result is more realistic roadmaps and stronger assurance for high-impact AI systems.

25. Full Operating Model and Engagement Method

NS AISCA is designed to operate as a continuous AI security programme. The operating model begins with baseline assessment and moves into funded remediation, quarterly measurement, assurance cycles and annual reassessment.

The full operating model lifecycle

This table outlines the lifecycle of an NS AISCA programme, explaining what happens in each phase, when it occurs, and what output the client receives. This is achieved by converting assessment results into funded remediation, assurance execution, maturity tracking and annual reassessment. It is used to plan client engagements and sustain AI security maturity beyond the initial assessment.

Phase	Timeline	Activities	Output
Baseline Assessment	Month 1-2	Complete full NS AISCA assessment, establish scores, identify gaps, compute readiness, and map regulatory obligations.	Scored assessment, AISCA score, standards matrix and 12-month roadmap.
Funded Roadmap	Month 2-3	Translate the roadmap into a funded programme, assign control owners, and define milestones and success metrics.	Approved programme plan, budget allocation and accountability matrix.
Quarterly Measurement	Ongoing	Track remediation, refresh evidence, update key control scores, and report to the CISO monthly and the board quarterly.	Updated dashboard, progress report and revised priorities.
Assurance Cycle	Per domain schedule	Execute threat models, red teams, adversarial tests, evidence reviews, and incident exercises.	Assurance evidence, findings register, and residual-risk record.
Annual	Annually	Perform a full reassessment against the prior	Updated scores, improvement

Phase	Timeline	Activities	Output
Reassessment		baseline, demonstrate improvement, and update mappings.	delta, regulatory evidence and new roadmap.

AI security cannot be sustained through a one-time assessment. The operating model turns findings into an ongoing management system. The result is continuous improvement, board visibility and stronger readiness for scrutiny.

The deliverable suite

This table summarizes the core outputs of the NS AISCA operating model, explains what each deliverable contains, and how each supports the overall AI security programme. This is achieved by separating the framework, control catalogue, workbook, matrix, board report, architecture patterns and assurance playbook into connected artefacts. It is used during project scoping to confirm what the client receives and how each artefact will be used.

Deliverable	Purpose
NS AISCA Framework Definition Document	Defines architecture, principles, domains, maturity model, scoring model, assurance method and operating model.
NS AISCA Control Catalogue	Contains all 108 controls with requirements, evidence expectations, maturity guidance and framework mapping.
NS AISCA Assessment Workbook	Includes domain sheets, dropdown scoring, evidence register, automated gap scoring, dashboard and roadmap.
NS AISCA Standards Mapping Matrix	Maps controls to EU AI Act, ISO/IEC 42001, ISO/IEC 23894, ISO/IEC 27001, ISO/IEC 27090, NIST, OWASP, MITRE, CSA, CISA/NCSC and SAIF.
NS AISCA Board Report Template	Reports executive posture, high-risk systems, maturity, top risks, control failures and remediation roadmap.
NS AISCA Technical Architecture Patterns	Defines secure chatbot, RAG, AI API, autonomous agent, MLSecOps, fine-tuning and third-party foundation-model patterns.
NS AISCA Assurance Playbook	Defines threat modelling, AI red teaming, adversarial testing, evidence review, incident exercises and reassessment.

It confirms that NS AISCA is a complete operating model. Each artefact has a defined purpose and connects to the assessment lifecycle. The result is smoother delivery, easier handover and stronger long-term client adoption.

26. Market Position & Competitive Differentiation

NS AISCA is positioned as a dedicated AI security controls architecture for regulated and high-impact AI environments. It is intentionally different from generic consulting checklists, conventional GRC tools and single-standard mappings.

The market differentiation model

This defines why NS AISCA is structurally different from generic consulting approaches and conventional GRC tooling. It compares capability coverage across generic consulting, generic GRC tools and the NS AISCA model. This is achieved by listing the capabilities that matter most in AI security and showing whether each alternative provides them at the control level. It is used in client discussions to explain the framework's distinctive value.

Capability	Generic Consulting	Generic GRC Tools	NS AISCA v1.0 + Nucleus Systems
AI-specific security architecture	Often generic IT security adapted to AI.	Usually generic control libraries with limited AI context.	108 AI-specific controls across 12 weighted domains.
GenAI, RAG and prompt security	Usually advisory guidance.	Limited or template-level coverage.	Dedicated D6 domain with prompt, RAG, validation, context and telemetry controls.
Agentic AI security	Often immature or	Rarely supported as a	Dedicated D7 domain with permission

Capability	Generic Consulting	Generic GRC Tools	NS AISCA v1.0 + Nucleus Systems
	absent.	distinct control area.	scopes, tool registry, autonomy limits and kill switches.
MLSecOps and supply chain	Project-dependent and manual.	Usually software-focused, not AI-BOM/model focused.	Dedicated D8 domain with AI-BOM, signed models, gates and update review.
Cross-framework alignment	Often manual mapping.	Partial mappings.	Mapped to EU AI Act, ISO, NIST, OWASP, MITRE, CSA, CISA/NCSC and SAIF.
Evidence-grade maturity	Often judgement-based.	Evidence collection may exist but not AI-specific.	Five evidence grades constrain maturity and support auditability.
Board-ready reporting	Manual narrative usually required.	Dashboards may lack AI security context.	AI security posture, top risks, failures, roadmap and assurance status are board-reportable.

The AI security market is crowded with partial solutions. NS AISCA integrates governance, engineering, assurance and standards mapping. The result is a stronger buyer case for organisations that need measurable maturity and defensible evidence.

27. About Nucleus Systems

Nucleus Systems (Pty) Ltd is a specialist digital trust, cybersecurity and AI governance firm headquartered in Centurion, South Africa. NS AISCA extends the Nucleus Systems AI governance portfolio by providing a dedicated technical security architecture for AI systems, GenAI applications, autonomous agents and AI-enabled products.

The Nucleus Systems differentiators

This defines the capabilities Nucleus brings to AI security architecture engagements and explains how the firm combines cybersecurity engineering, AI governance, regulatory alignment, solution architecture and continuous assessment capability. This is achieved by describing service differentiators that support delivery of NS AISCA in practical client environments. It is used to communicate why Nucleus Systems is positioned to lead AI security controls architecture work in Africa, the Middle East and global regulated markets.

Differentiator	Description
Proprietary Framework IP	NS AISCA v1.0 provides a proprietary 108-control, 12-domain AI security control architecture aligned to leading global sources.
Solution-Architecture-Led Delivery	Engagements are scoped to the client's AI systems, data flows, model types, agentic workflows, vendors and operating context.
Technical + Governance Depth	The approach combines cybersecurity engineering, MLSecOps, AI governance, data protection, cloud security, assurance and regulatory advisory.
Africa-Rooted, Globally Aligned	Nucleus Systems brings regional operating context while aligning to global standards and regulatory expectations.
Continuous Assessment Capability	Quarterly and annual reassessment maintain maturity visibility, evidence freshness and board reporting.
Tool-Enabled Delivery	The workbook, evidence register, roadmap and board report create a practical operating system for AI security management.

AI security clients need technical depth and governance credibility. Nucleus Systems can translate control architecture into evidence-based implementation and executive reporting. The result is a practical path from AI security uncertainty to measurable and continuously improving trust.

Real AI security is not a prompt filter, a model test, or a checkbox. It is the architecture of trust that allows AI systems to operate under adversarial pressure, regulatory scrutiny, and business-critical expectations.